

DetectKB

راهنمای کاربری

پایگاه دانش مهندسی تشخیص

ویرایش ۱.۰ مهر ۱۴۰۵

فهرست فصل‌ها

فصل ۱ آشنایی با DetectKB

فصل ۲ شروع کار

فصل ۳ قوانین تشخیص

فصل ۴ ورود و خروج قوانین

فصل ۵ پوشش MITRE ATT&CK

فصل ۶ رویدادهای Sysmon

فصل ۷ ابزارهای مهاجم

فصل ۸ گراف دانش

فصل ۹ صفحات دانش

فصل ۱۰ جست‌وجو و مستندسازی

فصل ۱۱ مدیریت سامانه

فصل ۱۲ میانبرهای صفحه‌کلید و ظاهر

فصل ۱۳ پرسش‌های رایج و عیب‌یابی

درباره‌ی این راهنما. این راهنما کار با همه‌ی بخش‌های DetectKB را قدم‌به‌قدم توضیح می‌دهد. رابط کاربری سامانه انگلیسی است؛ برای اینکه دکمه‌ها و منوها را راحت پیدا کنید، نام آن‌ها دقیقاً همان‌طور که روی صفحه دیده می‌شوند به‌صورت **پررنگ** آمده است، مثل **Import rules**. کلیدهای صفحه‌کلید و مقادیر فنی به شکل **Ctrl+K** نوشته شده‌اند.

تصاویر از محیط آزمایشی با حدود ۲۱۰۰ قانون واقعی از مخزن‌های عمومی Elastic، ESCU، Splunk و Sigma و Microsoft Sentinel گرفته شده‌اند. عدهای داخل تصاویر مربوط به همان داده‌ی نمونه است.

فصل ۱ – آشنایی با DetectKB

DetectKB یک پایگاه دانش برای تیم‌های مهندسی تشخیص (Detection Engineering) است. قوانین تشخیص، دانش پشت آن‌ها و منابع داده‌ای که به آن تکیه دارند در یک جا نگه داشته می‌شوند. سامانه از روی این داده‌ها نشان می‌دهد در برابر کدام تکنیک‌های مهاجم پوشش داریم، هر تشخیص به کدام داده وابسته است و کجا شکاف داریم.

مفاهیم پایه

مفهوم	توضیح
قانون تشخیص (Rule)	یک منطق شناسایی رفتار مخرب، همراه با کوئری (SPL، KQL، EQL یا Sigma)، شدت، وضعیت، تکنیک‌های ATT&CK و منبع داده.
وضعیت (Status)	draft پیش‌نویس · testing در حال تست · production فعال در محیط عملیاتی · deprecated کنار گذاشته شده.
شدت (Severity)	info · low · medium · high · critical
تکنیک ATT&CK	شناسه‌ی تکنیک مهاجم در چارچوب MITRE ATT&CK، مثل T1003.001 (استخراج حافظه‌ی LSASS). سامانه از نسخه‌ی v19.2 استفاده می‌کند.
رویداد Sysmon	نوع رویدادی که Sysmon ثبت می‌کند، مثل EID 1 (ساخت پروسه) یا EID 10 (دسترسی به پروسه).
منبع داده (Data Source)	جایی که لاگ از آن می‌آید، مثل Sysmon Operational Log. در سامانه به شکل یک صفحه‌ی دانش ثبت می‌شود.
ابزار مهاجم	فایل‌های مجاز سیستم‌عامل که مهاجم از آن‌ها سوءاستفاده می‌کند، از مخزن‌های LOLBAS، LOLDrivers و GTF0Bins.
صفحه‌ی دانش (Page)	هر محتوای متنی سامانه: قانون، مفهوم (Concept)، منبع داده، یادداشت (Note) و دستور SPL.

نقش‌ها و سطح دسترسی

هر کاربر یک یا چند نقش دارد. دکمه‌ها و منوهای کاربر اجازه‌ی استفاده از آن‌ها را ندارد، برایش نمایش داده نمی‌شوند.

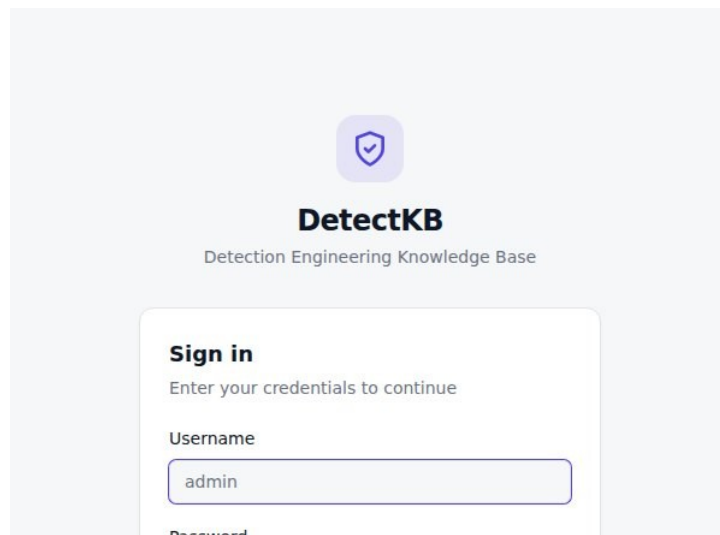
نقش	دسترسی
viewer	فقط مشاهده: صفحه‌ها، قوانین، تگ‌ها، گراف، پوشش ATT&CK و ساخت گزارش.
editor	همه‌ی دسترسی‌های viewer، به‌علاوه‌ی ساخت، ویرایش و حذف صفحه و قانون، ورود قوانین، مدیریت

نقش	دسترسی
	تگ و گرفتن پشتیبان.
admin	همه‌ی دسترسی‌ها، از جمله مدیریت کاربران، بازگردانی پشتیبان، گزارش فعالیت، انواع صفحه و به‌روزرسانی داده‌ی ابزارهای مهاجم.

فصل ۲ – شروع کار

ورود به سامانه

آدرس سامانه را در مرورگر باز کنید، نام کاربری و رمز عبور را وارد کنید و **Sign In** را بزنید. نام کاربری و رمز اولیه‌ی مدیر در پایان نصب نمایش داده می‌شود و در فایل `env` هم ثبت است.



شکل ۱ – صفحه‌ی ورود

نکته

اگر مدیر برای شما حساب ساخته یا رمزتان را بازنشانی کرده باشد، بعد از اولین ورود باید رمز جدیدی انتخاب کنید. تا رمز عوض نشود، سامانه به صفحه‌ی دیگری نمی‌رود. بعد از چند تلاش ناموفق پشت‌سرهم، ورود برای مدتی کوتاه قفل می‌شود. کمی صبر کنید و دوباره امتحان کنید.

آشنایی با محیط

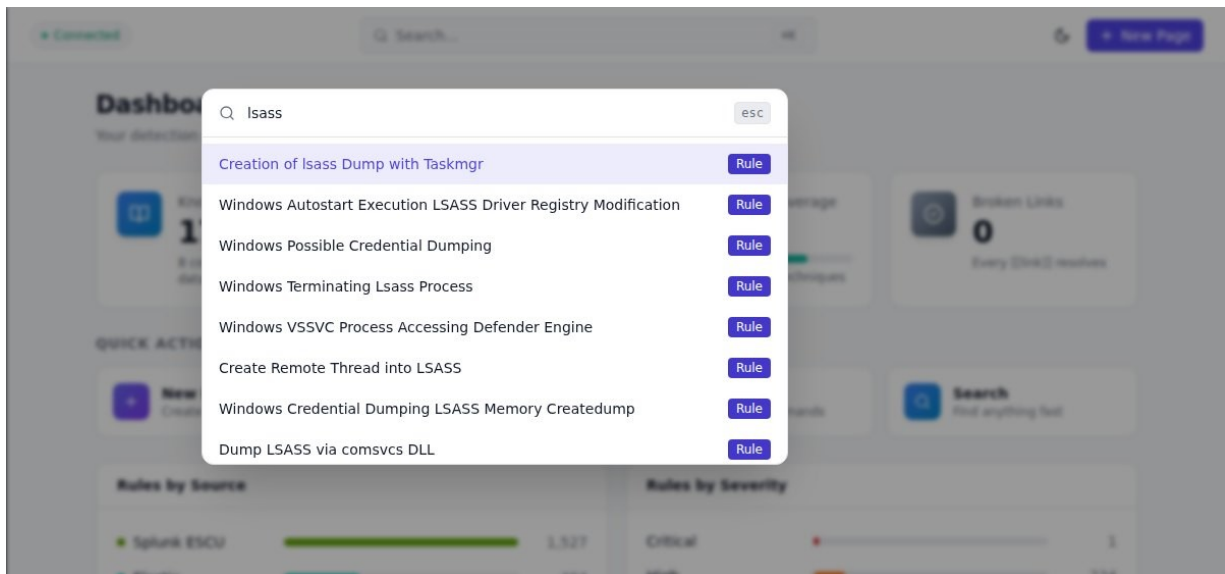
صفحه‌ی سامانه سه بخش ثابت دارد:

- **نوار کناری (سمت چپ):** دسترسی به همه‌ی بخش‌ها. بخش **Main** داشبورد است. بخش **Content** شامل فهرست صفحه‌ها، قوانین، پوشش ATT&CK، کتابخانه‌ی SPL، رویدادهای Sysmon، ابزارهای مهاجم، منابع داده، مفاهیم و مستندسازی است. **Saved views** نماهای ذخیره‌شده‌ی شماست. **Categories** دسته‌بندی صفحه‌هاست و با دکمه‌ی + دسته‌ی جدید ساخته می‌شود. **Tools** جست‌وجو، گراف دانش، لینک‌های شکسته، پشتیبان‌گیری و تنظیمات است. **Admin** فقط برای مدیر نمایش داده می‌شود. با **Collapse** پایین نوار، نوار کوچک می‌شود و فقط آیکون‌ها می‌مانند.

- **نوار بالا:** وضعیت اتصال به سرور (**Connected**)، جعبه‌ی جست‌وجوی سریع، دکمه‌ی تغییر حالت روشن و تاریک، و دکمه‌ی **New Page** برای ساخت صفحه‌ی جدید.
- **محتوای اصلی:** صفحه‌ای که باز کرده‌اید. بالای هر صفحه مسیر آن (breadcrumb) نمایش داده می‌شود و با کلیک روی هر بخش مسیر، به آن برمی‌گردید.

جست‌وجوی سریع

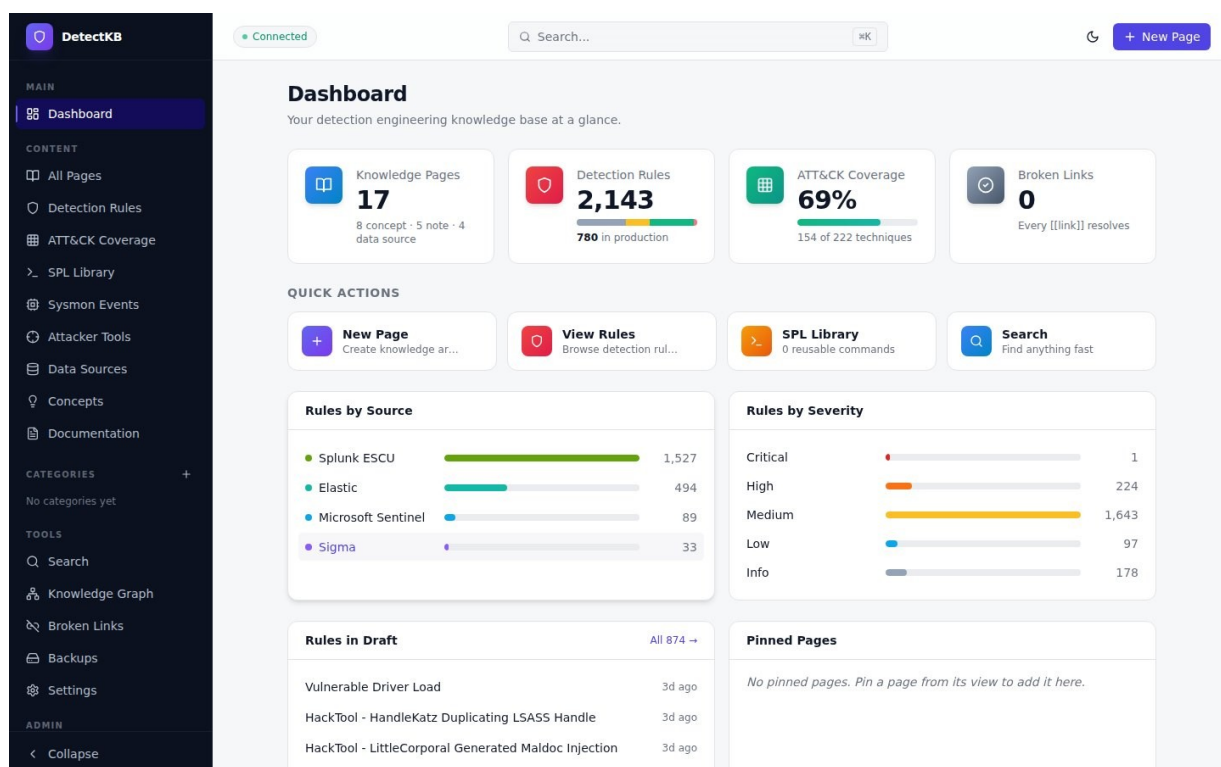
با **Ctrl+K** (در مک **⌘K**) یا کلیک روی جعبه‌ی **Search** در نوار بالا، پنجره‌ی جست‌وجوی سریع باز می‌شود. دست‌کم دو حرف تایپ کنید. نتیجه‌ها با کلیدهای جهت‌دار انتخاب و با **Enter** باز می‌شوند.



شکل ۲ – جست‌وجوی سریع با **Ctrl+K**

داشبورد

داشبورد اولین صفحه بعد از ورود است و خلاصه‌ی وضعیت پایگاه دانش را نشان می‌دهد:



شکل ۳ - داشبورد

- **Knowledge Pages:** تعداد صفحه‌های دانش (بدون قوانین)، به تفکیک نوع.
 - **Detection Rules:** تعداد کل قوانین، با نوار رنگی وضعیت‌ها و تعداد قوانین production.
 - **ATT&CK Coverage:** درصد تکنیک‌های ATT&CK که دست‌کم یک قانون فعال دارند.
 - **Broken Links:** تعداد لینک‌های ویکی که به صفحه‌ی ناموجود اشاره می‌کنند.
 - **Rules by Source** و **Rules by Severity:** تعداد قوانین به تفکیک منبع و شدت. با کلیک روی هر ردیف، فهرست قوانین با همان فیلتر باز می‌شود.
 - **Rules in Draft:** آخرین قوانین پیش‌نویس. **Pinned Pages:** صفحه‌هایی که سنجاق کرده‌اید. **Recent Activity:** آخرین صفحه‌های ویرایش‌شده.
- همه‌ی کارت‌های بالای داشبورد قابل کلیک‌اند و صفحه‌ی مربوط را باز می‌کنند.

فصل ۳ – قوانین تشخیص

صفحه‌ی **Detection Rules** از نوار کناری باز می‌شود و مرکز کار با قوانین است.

The screenshot shows the DetectKB interface for managing Detection Rules. The sidebar on the left contains navigation links for MAIN (Dashboard), CONTENT (All Pages, Detection Rules, ATT&CK Coverage, SPL Library, Sysmon Events, Attacker Tools, Data Sources, Concepts, Documentation), CATEGORIES (No categories yet), TOOLS (Search, Knowledge Graph, Broken Links, Backups, Settings), and ADMIN (Collapse). The main content area is titled 'Detection Rules' and shows a summary of rule counts by status: Draft (874), Testing (427), Production (780), and Deprecated (62). Below this is a search bar and filters for Status, Severity, and Source. A table lists individual rules with columns for Title, Status, Severity, MITRE Techniques, Data Source, and Updated. Each rule entry includes a checkbox, a title, a status tag (e.g., Production, Draft, Testing), a severity tag (e.g., High, Medium, Low), MITRE technique IDs, the data source, and the time since last update.

شکل ۴ – فهرست قوانین تشخیص

اجزای صفحه

- دکمه‌های بالا: **Save view** ذخیره‌ی فیلترها، **Export Sigma** خروجی **Import rules**، **Sigma** ورود قانون، و **New Rule** قانون جدید.
- **برچسب‌های وضعیت**: تعداد قوانین در هر وضعیت (Draft، Testing، Production، Deprecated). با کلیک روی هر کدام، فهرست به همان وضعیت فیلتر می‌شود و با کلیک دوباره فیلتر برداشته می‌شود.
- **جعبه‌ی جست‌وجو**: در عنوان، تکنیک، منبع داده، شناسه‌ی Sigma و منبع، و نام تگ جست‌وجو می‌کند.
- **فیلترها**: وضعیت (**Status**)، شدت (**Severity**) و منبع قانون (**Source**). گزینه‌ی **Written here** یعنی قوانینی که در خود سامانه نوشته شده‌اند.
- **دکمه‌ی تراکم**: آیکون کنار فیلترها، ردیف‌ها را فشرده یا راحت نمایش می‌دهد. انتخاب شما در همان مرورگر به خاطر سپرده می‌شود.
- **جدول**: عنوان (با منبع و تگ‌ها)، وضعیت، شدت، تکنیک‌های MITRE، منبع داده و زمان آخرین تغییر.
- **پایین جدول**: تعداد نتیجه‌ها، تعداد ردیف در هر صفحه (۲۵، ۵۰ یا ۱۰۰) و دکمه‌های رفتن به صفحه‌ی بعد و قبل.

جست‌وجو، فیلتر و مرتب‌سازی

با کلیک روی سر ستون‌های **Updated**، **Title**، **Status**، **Severity**، فهرست بر همان ستون مرتب می‌شود. کلیک دوباره ترتیب را برعکس می‌کند. شدت و وضعیت به ترتیب منطقی خودشان مرتب می‌شوند، نه الفبایی.

با کلیک روی شناسه‌ی یک تکنیک در جدول، مثل **T1003.001**، فقط قوانین همان تکنیک نشان داده می‌شوند. با کلیک روی برچسب منبع، مثل **Sigma**، هم فقط قوانین همان منبع می‌مانند. فیلتر تکنیک بالای جدول با علامت × نمایش داده می‌شود و با کلیک روی × برداشته می‌شود.

The screenshot displays the 'Detection Rules' management page. At the top, there are buttons for 'Save view', 'Export Sigma', 'Import rules', and 'New Rule'. Below these, a status filter bar shows counts for Draft (1), Testing (0), Production (0), and Deprecated (0). A search bar and three dropdown filters (Status: All, Severity: Critical, Source: All) are present. The main table lists rules with columns: Title, Status, Severity, MITRE Techniques, Data Source, and Updated. One rule is visible: 'Potential Invoke-Mimikatz PowerShell Script' with status 'Draft', severity 'Critical', and MITRE techniques T1003, T1003.001, and T1003.002. The data source is 'PowerShell Logs' and it was updated '3d ago'. A 'Showing 1-1 of 1 rule' message and a 'Per page 50' dropdown are at the bottom.

شکل ۵ – فهرست قوانین با فیلتر شدت critical، مرتب‌شده بر اساس عنوان

نکته

همه‌ی فیلترها، جست‌وجو و شماره‌ی صفحه در آدرس صفحه (URL) ذخیره می‌شوند. می‌توانید آدرس را برای همکاران بفرستید تا دقیقاً همین فهرست را ببینند. دکمه‌ی Back مرورگر هم فیلتر قبلی را برمی‌گرداند.

پیش‌نمایش کناری

با کلیک روی عنوان یک قانون، جزئیات آن در یک پنل کنار فهرست باز می‌شود و فهرست سر جایش می‌ماند. این پنل برای مرور سریع چند قانون پشت‌سرهم است.

Detection Rules
31

Save view

Export Sigma

Import rules

New Rule

	Draft	Testing	Production	Deprecated
Potential Credential Dumping Activity Via LSASS		6	11	2

Status: All

Severity: All

Source: All

Title	Status	Severity
LSASS Access From Potentially White-Listed Processes	Production	High
Potential Credential Dumping Activity Via LSASS	Testing	Medium
HackTool - HandleKatz Duplicating LSASS Handle	Draft	High
LSASS Memory Access by Tool With Dump Keyword In Name	Production	High
Suspicious LSASS Access Via MalSecLogon	Draft	High

Potential Credential Dumping Activity Via LSASS

Testing

Medium

Sigma

Open page Edit

ATT&CK
TA0006 T1003.001

DATA
product:windows category:process_access
Sysmon 10 · Process Access

TAGS
#sigma

```

SPL      Sigma      1 line
TargetImage=="\\lsass.exe" GrantedAccess IN ("*0x1038*", "*0x1438*",
"*0x143a*", "*0x1fffff") CallTrace IN ("*dbgcore.dll*", "*dbghelp.dll*",
"*kernel32.dll*", "*kernelbase.dll*", "*ntdll.dll") NOT (SourceUser IN
("**AUTHORI**", "**AUTORI**")) NOT ((CallTrace=="*:\\Windows\\Temp\\asgard2-agent\\*"
CallTrace="*\\thor\\thor64.exe+*" CallTrace="*\\UNKNOWN(*"
GrantedAccess="0x103800") OR SourceImage IN ("*:\\Windows\\Sysmon64.exe",
"*:\\Windows\\Sysmon64a.exe"))
          
```

FALSE POSITIVES
Unknown

DESCRIPTION
Detects process access requests to the LSASS process with specific call trace calls and access masks. This behaviour is expressed by many credential dumping tools such as Mimikatz, NanoDump, Invoke-Mimikatz, Procdump and even the Taskmgr dumping feature.

شکل ۶ - پنل پیش‌نمایش قانون

- بالای پنل: عنوان، وضعیت، شدت و منبع قانون. ▲ و ▼ قانون قبلی و بعدی فهرست را نشان می‌دهند و × پنل را می‌بندد.
- **Open page** صفحه‌ی کامل قانون را باز می‌کند و **Edit** صفحه‌ی ویرایش را.
- بخش‌های پنل: تکنیک‌ها و تاکتیک‌های ATT&CK، منبع داده و رویدادهای Sysmon، تگ‌ها، کوئری‌ها (در تب‌های جدا)، موارد مثبت کاذب، توضیح و منابع.
- وقتی پنل باز است، ستون‌های تکنیک، منبع داده و تاریخ از جدول پنهان می‌شوند تا عنوان‌ها جا داشته باشند.

نکته

برای باز کردن صفحه‌ی کامل قانون به جای پیش‌نمایش، هنگام کلیک کلید **Ctrl** را نگه دارید (در مک %). صفحه در تب جدید باز می‌شود.

انتخاب قوانین و عملیات گروهی

با تیک ستون اول می‌توانید چند قانون را انتخاب کنید. تیک سر جدول همه‌ی قوانین صفحه‌ی فعلی را انتخاب می‌کند. انتخاب‌ها با رفتن به صفحه‌ی بعد حفظ می‌شوند، ولی با تغییر فیلتر پاک می‌شوند.

وقتی قانونی انتخاب شود، نواری پایین صفحه ظاهر می‌شود:

☒	Driver Load From A Temporary Directory	Production	High	T1543.003	product:windows category:driver_load	3d ago
☒	Vulnerable Driver Load	Draft	High	T1543.003 T1068	product:windows category:driver_load	3d ago
☐	Malicious Driver Load	Production	High	T1543.003 T1068	product:windows category:driver_load	3d ago
☐	PUA - Process Hacker Driver Load	Testing	High	T1543	product:windows category:driver_load	3d ago
☐	Malicious Driver Load By Name	Testing	Medium	T1543.003 T1068	product:windows category:driver_load	3d ago
☐	WinDivert Driver Load	Production	High	T1599.001 T1557.001	product:windows category:driver_load	3d ago
☐	Vulnerable Driver Load By Name	Testing	Low	T1543.003 T1068	product:windows category:driver_load	3d ago
☐	PUA - System Informer Driver Load	Production	Medium	T1543	product:windows category:driver_load	3d ago
☐	Vulnerable WinRing0 Driver Load	Testing	High	T1543.003	product:windows category:driver_load	3d ago
☐	LSASS Access From Potentially White-Listed Processes	Draft		T1003.001	product:windows category:process_access	3d ago
☐	Credential Dumping Attempt Via WerFault	Testing		T1003.001	product:windows category:process_access	3d ago
☐	Potential Credential Dumping Attempt Via LSASS	Testing	Medium	T1003.001	product:windows category:process_access	3d ago

شکل ۷ - نوار عملیات گروهی و منوی تغییر وضعیت

- **Select all ... matching**: اگر تمامی قوانین صفحه را انتخاب کرده باشید، این گزینه تمامی قوانین منطبق با فیلتر فعلی را انتخاب می‌کند، حتی آن‌هایی که در صفحه‌های بعدی‌اند.
- **Status و Severity**: تغییر وضعیت یا شدت تمامی قوانین انتخاب‌شده.
- **Tag**: افزودن یا حذف یک تگ. نام تگ را بنویسید و **Add tag** یا **Remove tag** را بزنید.
- **Export Sigma**: خروجی Sigma فقط از قوانین انتخاب‌شده.
- **Delete**: حذف قوانین انتخاب‌شده، بعد از تأیید.
- **x** یا کلید **Esc**: انتخاب را پاک می‌کند.

توجه

حذف گروهی قابل بازگشت نیست. صفحه‌ی قانون، کوئری‌ها، لینک‌ها و تاریخچه‌اش حذف می‌شوند. اگر مطمئن نیستید، قبل از حذف پشتیبان بگیرید (فصل ۱۱).

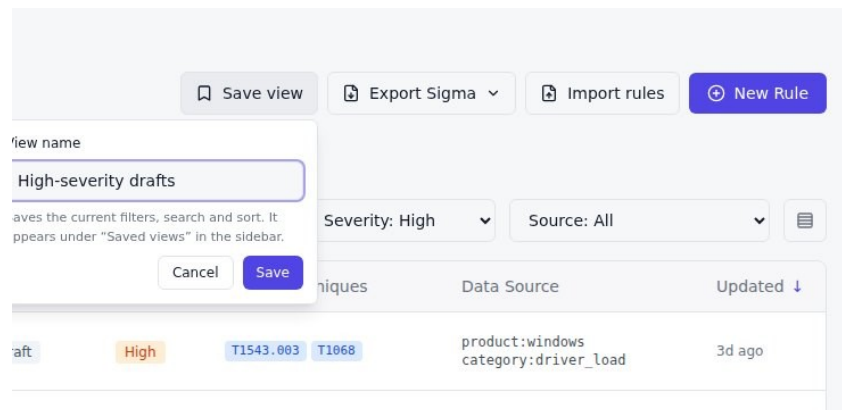
نماهای ذخیره‌شده

اگر ترکیبی از فیلترها را زیاد استفاده می‌کنید، مثلاً «قوانین draft با شدت high»، آن را ذخیره کنید:

1. فیلترها، جست‌وجو و مرتب‌سازی را تنظیم کنید.

2. روی **Save view** بالای صفحه کلیک کنید.

3. یک نام وارد کنید (سامانه نامی از روی فیلترها پیشنهاد می‌دهد) و **Save** را بزنید.

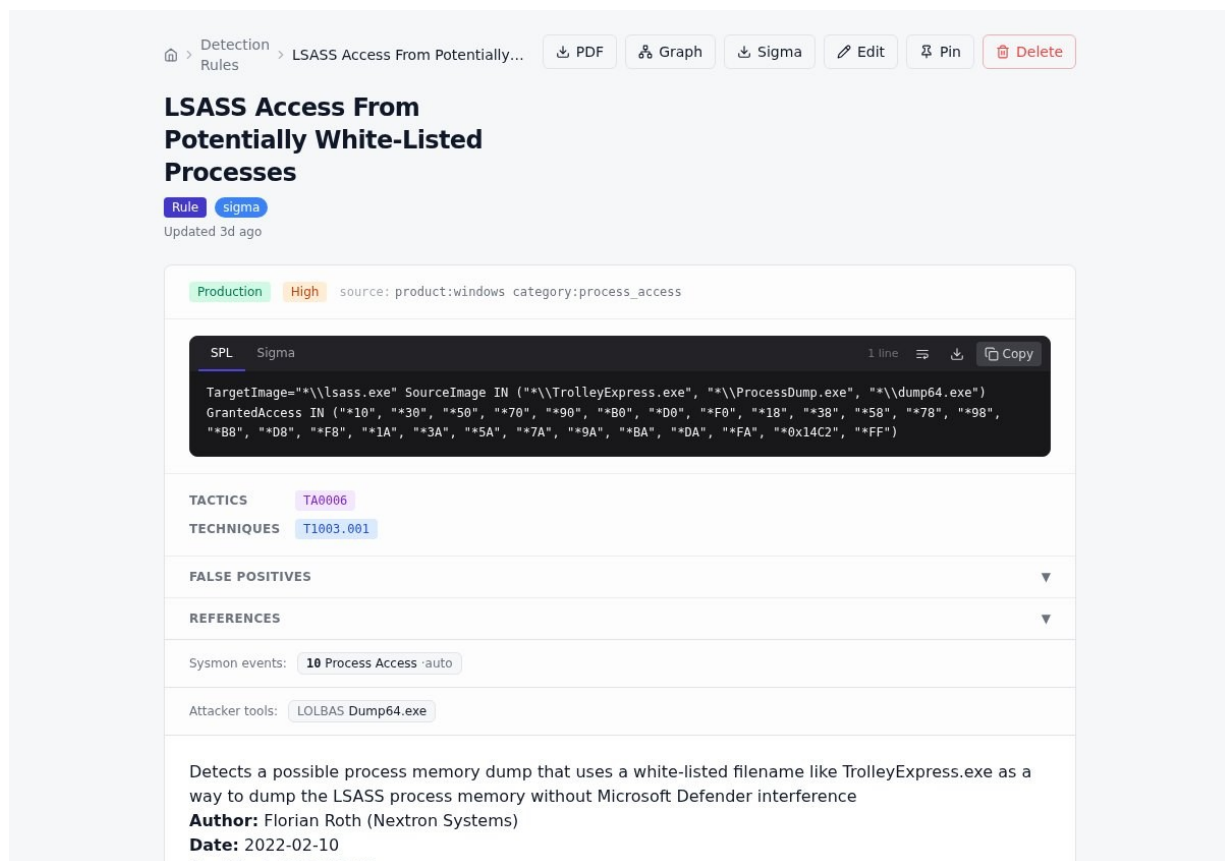


شکل ۸ – ذخیره‌ی نما

نما در بخش **Saved views** نوار کناری اضافه می‌شود و با یک کلیک همان فیلترها را برمی‌گرداند. برای حذف، ماوس را روی نام نما نگه دارید و **x** را بزنید. نماها برای هر کاربر جدا هستند. این دکمه در صفحه‌ی **All Pages** و گراف دانش هم هست.

صفحه‌ی قانون

با **Open page** در پیش‌نمایش، یا **Ctrl+کلیک** روی عنوان، صفحه‌ی کامل قانون باز می‌شود.



شکل ۹ – صفحه‌ی یک قانون Sigma

- **دکمه‌های بالا: PDF** خروجی PDF از صفحه، **Graph** نمایش قانون در گراف دانش، **Sigma** دانلود فایل **Edit**، **Sigma** ویرایش، **Pin** سنجاق به داشبورد، و **Delete** حذف.
- **کادر کوئری‌ها:** کوئری‌های قانون در تب‌های جدا: **SPL**، کوئری اصلی قوانین Elastic و Sentinel (مثل **EQL** یا **KQL**)، **Sigma**، و فایل اصلی واردشده (**Original** ...). هر تب دکمه‌های کپی (**Copy**)، دانلود و شکستن خطوط بلند دارد. آخرین تبی که انتخاب کرده‌اید در قانون بعدی هم باز می‌ماند.
- **Tactics / Techniques:** با کلیک روی هر شناسه، فهرست قوانین همان تکنیک یا تاکتیک باز می‌شود.
- **False Positives, References, Test Notes:** با کلیک باز می‌شوند.
- **Sysmon events:** رویدادهایی که قانون به آن‌ها وابسته است. برچسب **auto** یعنی سامانه آن را از کوئری تشخیص داده است.
- **Attacker tools:** ابزارهای LOLBAS، GTFEBins یا LOLDrivers که در کوئری قانون آمده‌اند.
- **Backlinks:** صفحه‌هایی که با لینک ویکی به این قانون اشاره کرده‌اند.

The screenshot displays the DetectKB interface for a Sigma rule titled "Potential Credential Access via LSASS Memory Dump". The rule is categorized as "Rule" and "elastic", and was updated 3 days ago. It is associated with the "Sysmon" source and has a "High" severity. The rule is written in EQL and includes comments in Persian. Below the rule, there are sections for "TACTICS" (TA0006, TA0002), "TECHNIQUES" (T1003, T1003.001, T1106), and "REFERENCES" (10 Process Access: auto). A description at the bottom explains that the rule identifies suspicious access to LSASS handle from a call trace pointing to DBGHelp.dll or DBGCore.dll, which both export the MiniDumpWriteDump method that can be used to dump LSASS memory content in.

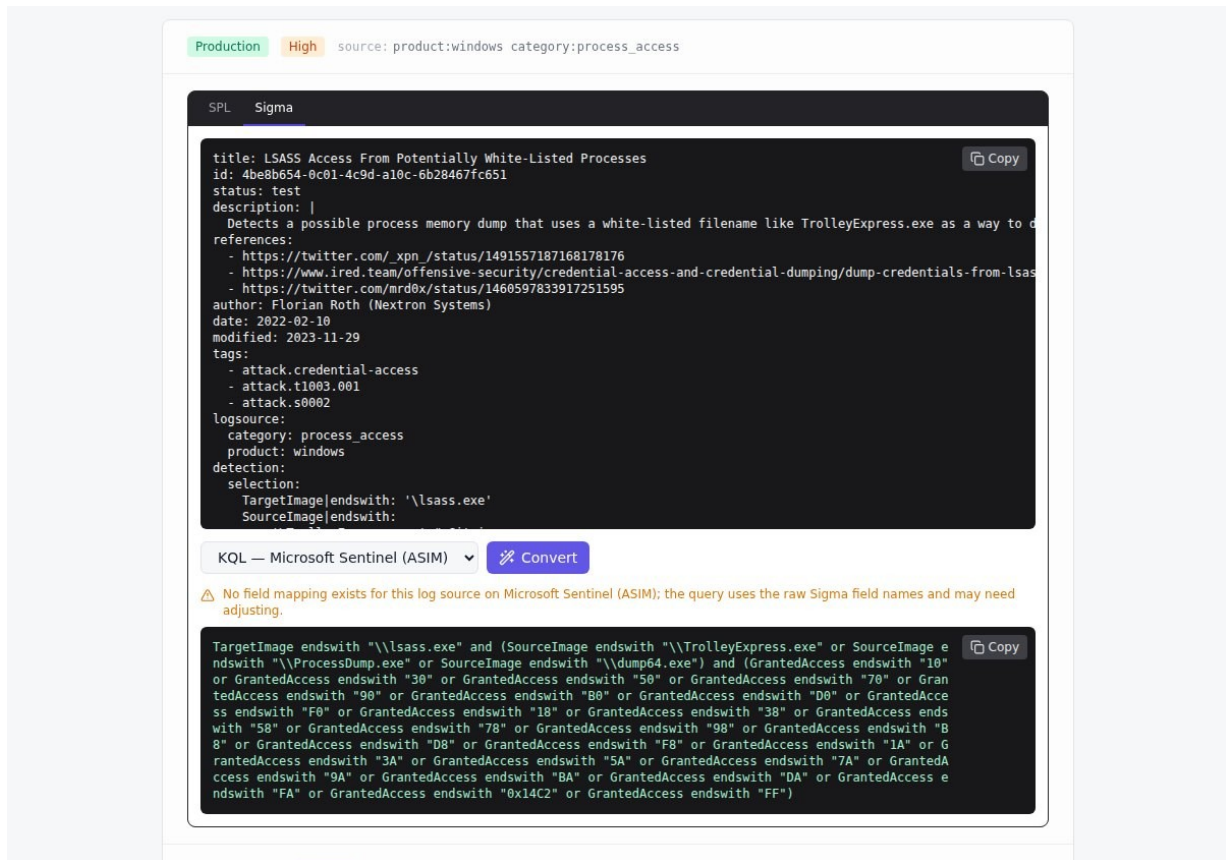
شکل ۱۰ — قانون Elastic با تب کوئری EQL و فایل اصلی

تبدیل Sigma به زبان SIEM

برای قانونی که منبع Sigma دارد، می‌توانید کوئری را برای SIEM خودتان بسازید:

1. در کادر کوئری‌ها، تب **Sigma** را باز کنید.

2. زبان مقصد را انتخاب کنید: **SPL — Splunk**، **KQL — Microsoft Defender XDR**، **KQL — Elastic (ECS)**، **Microsoft Sentinel (ASIM)** یا **Lucene — Elastic (ECS)**.
3. **Convert** را بزنید. کوئری ساخته شده زیر آن نمایش داده می شود و با **Copy** کپی می شود.



شکل ۱۱ – تبدیل قانون Sigma به KQL برای Microsoft Sentinel

نکته

اگر برای منبع لاگ قانون نگاشت فیلدی در زبان مقصد وجود نداشته باشد، پیام زردرنگی نمایش داده می شود. در این حالت کوئری با نام های اصلی فیلدهای Sigma ساخته شده و باید آن را با نام فیلدهای محیط خود تطبیق دهید.

ساخت و ویرایش قانون

برای قانون جدید، **New Rule** را در صفحه قوانین بزنید. برای ویرایش، **Edit** را در صفحه قوانین بزنید. فرم دو بخش دارد:

🏠 > Pages > Edit: Detect Credential Dumpin...

Edit Page

Cancel Save

Title *

Detect Credential Dumping through LSASS access

Type Category Tags (comma-separated)

Rule — None — splunk-escu ☐ Pinned

Content Type [[Page Title]] to link pages

B I [Icons] [Icons]

The following analytic detects attempts to read LSASS memory, indicative of credential dumping. It leverages Sysmon EventCode 10 and checks for "PROCESS_VM_READ" with query information access on lsass.exe.

How to implement

This search needs Sysmon Logs and a sysmon configuration, which includes EventCode 10 with lsass.exe. This search uses an input macro named `sysmon`. We strongly recommend that you specify your environment-specific configurations (index, source, sourcetype, etc.) for Windows Sysmon logs. Replace the macro definition with configurations for your Splunk environment. The search also uses a post-filter macro designed to filter out known false positives.

Data sources

- Sysmon EventID 10

Analytic stories

- Detect Zerologon Attack
- CISA AA23-347A
- Credential Dumping
- BlackSuit Ransomware

The following analytic detects attempts to read LSASS memory, indicative of credential dumping. It leverages Sysmon EventCode 10 and checks for "PROCESS_VM_READ" with query information access on lsass.exe.

How to implement

This search needs Sysmon Logs and a sysmon configuration, which includes EventCode 10 with lsass.exe. This search uses an input macro named `sysmon`. We strongly recommend that you specify your environment-specific configurations (index, source, sourcetype, etc.) for Windows Sysmon logs. Replace the macro definition with configurations for your Splunk environment. The search also uses a post-filter macro designed to filter out known false positives.

Detection Rule Details

شکل ۱۲ - بخش بالای فرم: عنوان، نوع، دسته، تگ‌ها و متن توضیح

- **Title:** عنوان قانون (اجباری).
- **Type:** نوع صفحه. برای قانون، **Rule** است.
- **Category** و **Tags:** دسته‌بندی و تگ‌ها. تگ‌ها را با ویرگول جدا کنید.
- **Pinned:** سنجاق کردن صفحه به داشبورد.
- **Content:** توضیح قانون به زبان Markdown. سمت چپ متن را می‌نویسید و سمت راست نتیجه را می‌بینید. برای لینک به صفحه‌ی دیگر، [] تایپ کنید (فصل ۹).

Detection Rule Details

Status

Testing

Severity

Medium

SPL Query

```

`sysmon`
EventCode=10
TargetImage="*\\lsass.exe"

...

Convert GrantedAccess from hexadecimal to decimal.
Match "PROCESS_VM_READ" with either "PROCESS_QUERY_LIMITED_INFORMATION" or
"PROCESS_QUERY_INFORMATION", which represent the either the "0x1010" or "0x1410" hexadecimal
masks

```

Copy

Other query language (KQL, EQL, ES|QL, Lucene)

Sigma rule (optional — source for SPL/KQL/EQL conversion and Sigma export)

MITRE Tactics

TA0006, TA0003

Comma-separated tactic IDs

MITRE Techniques

T1003.001

Comma-separated technique IDs

Data Source

Sysmon EventID 10

False Positives

The activity may be legitimate. Other tools can access lsass for legitimate reasons, and it's possible this event could be generated in those cases. In these cases, false positives should be fairly obvious and you may need to tweak the search to eliminate noise.

شکل ۱۳ – بخش Detection Rule Details: وضعیت، شدت، کوئری‌ها و ATT&CK

فیلد	توضیح
Status / Severity	وضعیت و شدت قانون.
SPL Query	کوئری Splunk قانون.
Other query language	کوئری به زبان دیگر (KQL, EQL, ES QL, Lucene) و انتخاب زبان آن.
Sigma rule	متن YAML قانون Sigma (اختیاری). از روی آن می‌شود کوئری ساخت و خروجی Sigma گرفت. با گزینه‌ی تبدیل به Splunk، نتیجه مستقیم در SPL Query قرار می‌گیرد.
MITRE Tactics	شناسه‌ی تاکتیک‌ها با ویرگول، مثل TA0006, TA0003.
MITRE Techniques	شناسه‌ی تکنیک‌ها با ویرگول، مثل T1003.001.
Data Source	منبع داده‌ی قانون به صورت متن.
False Positives	مواردی که ممکن است قانون به اشتباه هشدار بدهد.
References	منابع و لینک‌ها، هر کدام در یک خط.
Test Notes	روش تست، نتیجه‌ی مورد انتظار و پیش‌نیازهای محیط.
Sysmon events	رویدادهایی که قانون به آن‌ها وابسته است (پایین فرم).

System Event ID

False Positives

The activity may be legitimate. Other tools can access lsass for legitimate reasons, and it's possible this event could be generated in those cases. In these cases, false positives should be fairly obvious and you may need to tweak the search to eliminate noise.

References

<https://www.microsoft.com/en-us/security/blog/2022/10/05/detecting-and-preventing-lsass-credential-dumping-attacks/>
<https://attack.mitre.org/techniques/T1003/001/>

One URL per line

Test Notes

Describe how to test this rule, expected results, environment requirements...

Sysmon events

Events this page depends on. Links are also detected automatically from the SPL query / Sigma logsource (e.g. EventCode=10 with Sysmon, or category: process_access) when you save.

1 Process Creation

2 File Creation Time Changed

3 Network Connection

4 Sysmon Service State Changed

5 Process Terminated

6 Driver Loaded

7 Image Loaded

8 CreateRemoteThread

9 RawAccessRead

10 Process Access (auto)

11 FileCreate

12 Registry Object Created/Deleted

13 Registry Value Set

14 Registry Key/Value Renamed

15 FileCreateStreamHash

16 ServiceConfigurationChange

17 Pipe Created

18 Pipe Connected

19 WMI EventFilter Activity

20 WMI EventConsumer Activity

21 WMI ConsumerToFilter Binding

22 DNS Query

23 File Delete Archived

24 Clipboard Change

25 Process Tampering

26 File Delete Detected

27 File Block Executable

28 File Block Shredding

29 File Executable Detected

شکل ۱۴ – انتخاب رویدادهای Sysmon؛ رویداد 10 به طور خودکار تشخیص داده شده است

سامانه هنگام ذخیره، رویدادهای Sysmon را از کوئری (مثل `EventCode=10`) یا logsource قانون Sigma (مثل `category: process_access`) خودکار تشخیص می‌دهد. رویدادهای خودکار با **(auto)** مشخص شده‌اند. با کلیک روی هر رویداد، آن را دستی اضافه یا حذف می‌کنید.

در پایان **Save** را بزنید. **Cancel** بدون ذخیره برمی‌گردد.

فصل ۴ – ورود و خروج قوانین

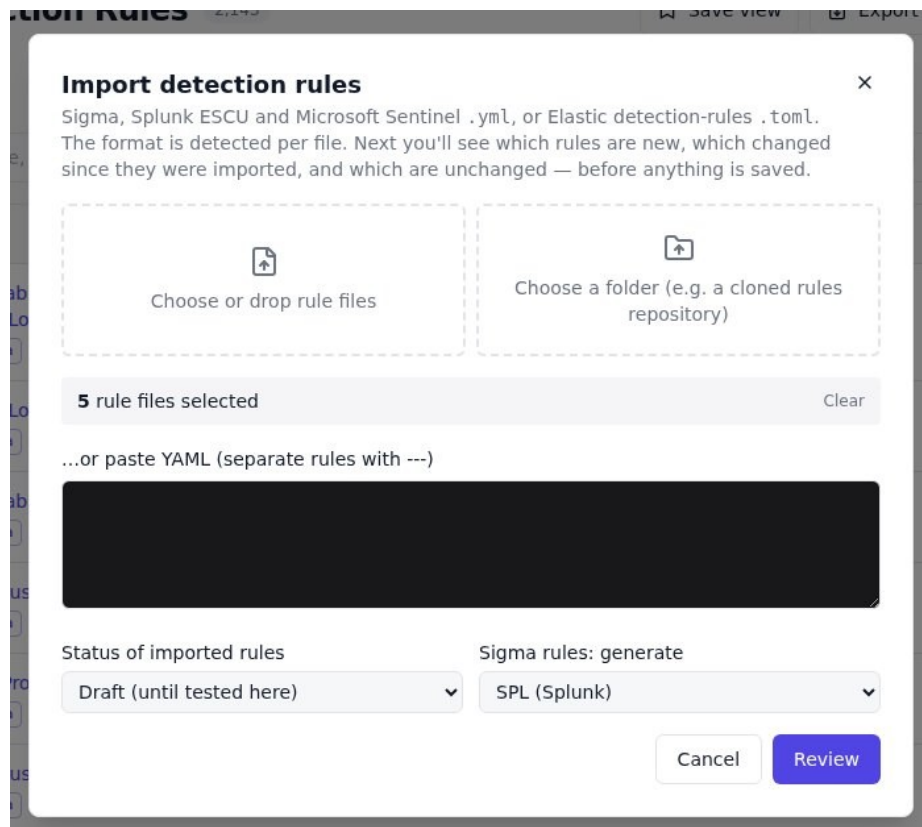
قوانین را می‌توانید از مخزن‌های عمومی یا فایل‌های خودتان وارد کنید. قالب‌های پشتیبانی‌شده:

- **Sigma** – فایل `.yaml`
- **Splunk ESCU** (security_content) – فایل `.yaml`
- **Microsoft Sentinel** – فایل `.yaml`
- **Elastic detection-rules** – فایل `.toml`

قالب هر فایل خودکار تشخیص داده می‌شود و می‌توانید چند قالب را با هم وارد کنید.

مراحل ورود

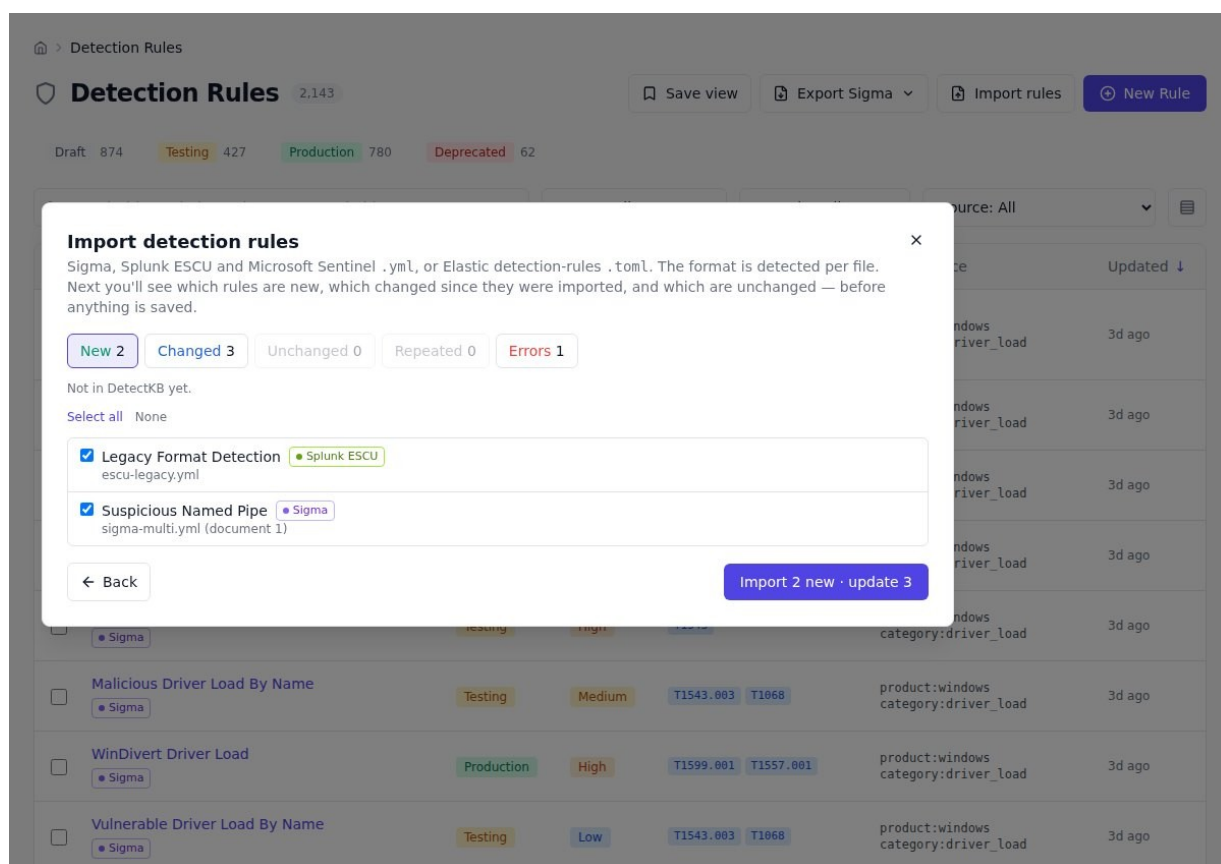
1. در صفحه‌ی قوانین، **Import rules** را بزنید.
2. فایل‌ها را انتخاب یا روی کادر رها کنید (**Choose or drop rule files**)، یا یک پوشه‌ی کامل انتخاب کنید (**Choose a folder**)، مثلاً پوشه‌ی clone شده‌ی مخزن SigmaHQ. می‌توانید متن YAML را هم مستقیم در کادر پایین بچسبانید. چند قانون را با --- از هم جدا کنید.
3. در **Status of imported rules** مشخص کنید قوانین با وضعیت **Draft** وارد شوند (پیشنهادی) یا وضعیت اعلام‌شده در منبع حفظ شود.
4. در **Sigma rules: generate** مشخص کنید برای قوانین Sigma کوئری SPL ساخته شود یا نه.
5. **Review** را بزنید. هنوز چیزی ذخیره نشده است.



شکل ۱۵ — پنجره‌ی ورود قوانین

بازبینی قبل از ذخیره

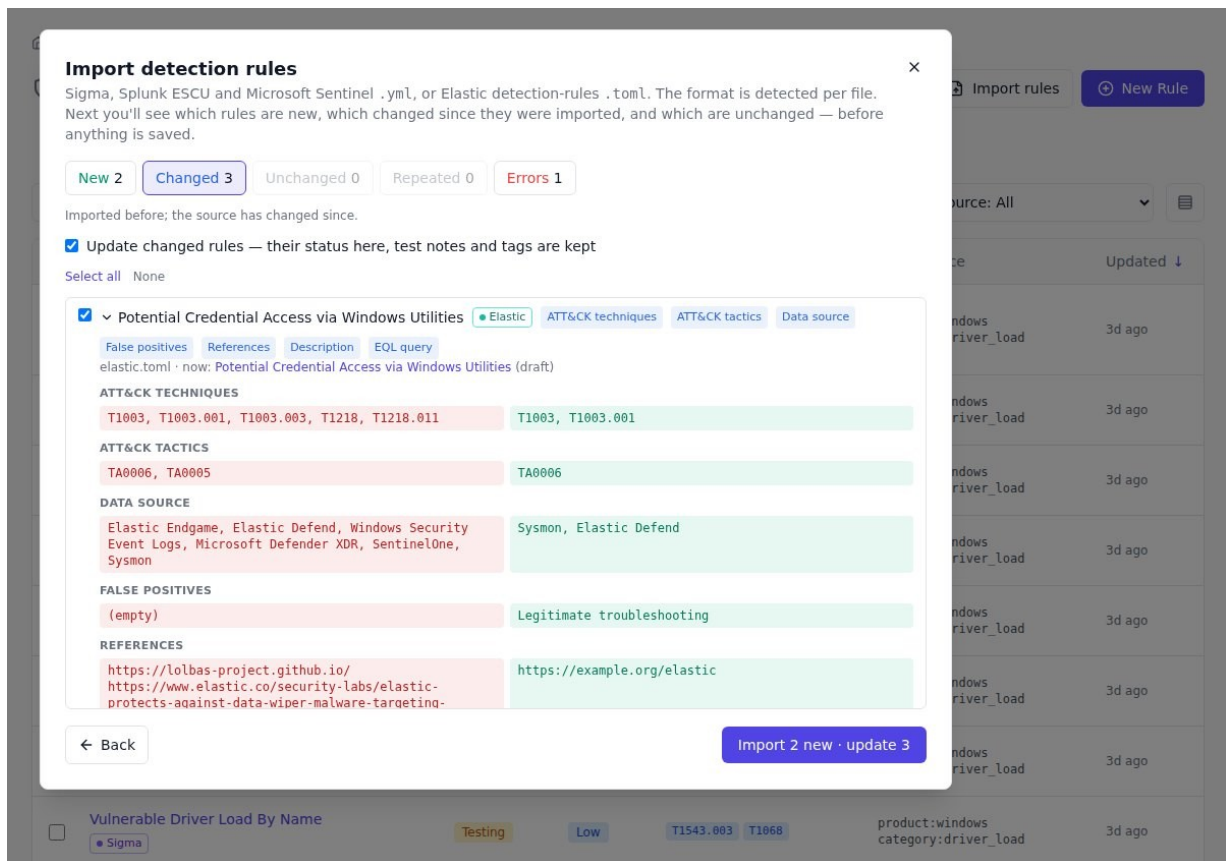
در مرحله‌ی بازبینی، قوانین در پنج دسته قرار می‌گیرند:



شکل ۱۶ – صفحه‌ی بازبینی: دسته‌ی قوانین جدید

دسته	معنی	رفتار
New	قانونی که هنوز در سامانه نیست.	ساخته می‌شود؛ می‌توانید تیک هر کدام را بردارید.
Changed	قبلاً وارد شده، ولی منبع اصلی از آن زمان تغییر کرده است.	اگر Update changed rules روشن باشد، به‌روز می‌شود.
Unchanged	قبلاً وارد شده و با منبع یکسان است.	نادیده گرفته می‌شود.
Repeated	همین قانون در همین آپلود قبلاً آمده است.	نادیده گرفته می‌شود.
Errors	فایل خوانده نشد، مثلاً به دلیل YAML نامعتبر یا فیلد ناقص.	نادیده گرفته می‌شود و علت خطا نمایش داده می‌شود.

در دسته‌ی **Changed**، با کلیک روی عنوان هر قانون، تفاوت فیلدها دیده می‌شود: مقدار فعلی با زمینه‌ی قرمز و مقدار جدید با زمینه‌ی سبز.



شکل ۱۷ – تفاوت فیلد به فیلد یک قانون تغییرکرده

نکته

اگر قانون جدیدی هم نام یک قانون موجود باشد، سامانه آن را به عنوان «احتمالاً همان تشخیص از منبعی دیگر» علامت می‌زند. با **Leave those out** می‌توانید همه‌ی این موارد را کنار بگذارید. در به‌روزرسانی یک قانون، وضعیت فعلی آن در سامانه، یادداشت‌های تست و تگ‌ها حفظ می‌شوند.

در پایان، دکمه‌ی پایین (مثلاً **Import 2 new · update 3**) را بزنید. بعد از ورود، فهرست قوانین ساخته‌شده، به‌روزرشده، نادیده‌گرفته‌شده و خطاها نمایش داده می‌شود.

توجه

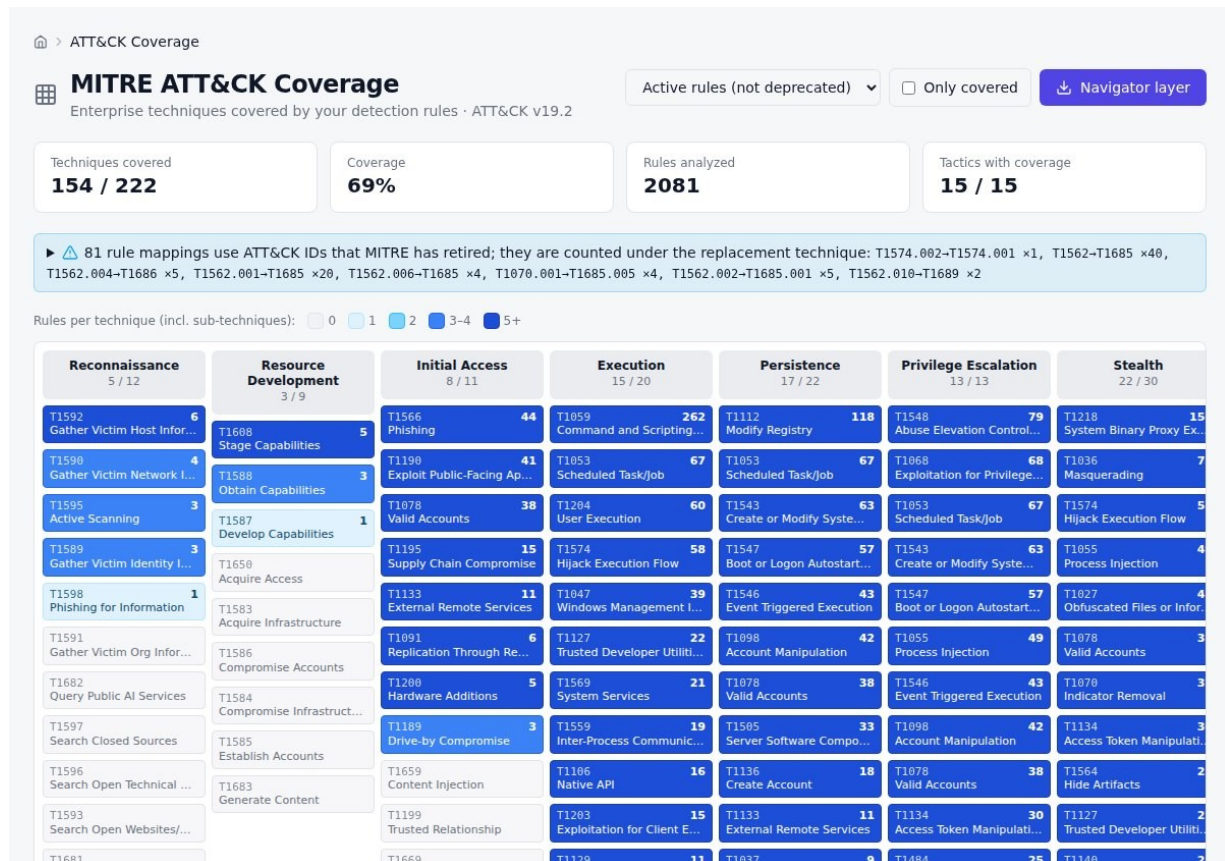
قوانین منابع دیگر برای مدل داده‌ی همان محصول نوشته شده‌اند، مثل Elastic ECS، Splunk CIM یا جدول‌های Sentinel. قبل از استفاده، نام فیلدها، index و sourcetype را با محیط خود تطبیق دهید و قانون را در وضعیت testing تست کنید.

خروجی Sigma

- **همه قوانین: منوی Export Sigma** در صفحه قوانین. گزینه **Rules with a Sigma source** فقط قوانینی را که منبع Sigma دارند خروجی می‌دهد. گزینه **All rules** برای بقیه قوانین هم یک اسکلت Sigma می‌سازد که باید کامل شود.
- **قوانین انتخاب شده: Export Sigma** در نوار عملیات گروهی.
- **یک قانون: دکمه Sigma** در صفحه قانون.

فصل ۵ – پوشش MITRE ATT&CK

صفحه **ATT&CK Coverage** ماتریس کامل ATT&CK Enterprise را نشان می‌دهد. هر ستون یک تاکتیک است و هر خانه یک تکنیک.



شکل ۱۸ – ماتریس پوشش ATT&CK

- **کارت‌های بالا:** تعداد تکنیک‌های پوشش داده شده، درصد پوشش، تعداد قوانین بررسی شده و تعداد تاکتیک‌هایی که دست‌کم یک قانون دارند.
 - **رنگ خانه‌ها:** تعداد قوانین تکنیک و زیرتکنیک‌هایش. هر چه تیره‌تر، قوانین بیشتر. خاکستری یعنی بدون قانون. راهنمای رنگ بالای ماتریس است.
 - **فیلتر وضعیت:** پیش‌فرض همه قوانین به جز deprecated حساب می‌شوند. می‌توانید فقط **Production** یا **Production + testing** را ببینید.
 - **Only covered:** فقط تکنیک‌های دارای قانون.
 - **Navigator layer:** دانلود لایه برای ATT&CK Navigator، ابزار رسمی MITRE.
- با کلیک روی هر خانه، جزئیات آن تکنیک زیر ماتریس باز می‌شود: قوانینی که مستقیم به تکنیک نگاشت شده‌اند، وضعیت پوشش هر زیرتکنیک، و لینک به سایت MITRE، زنجیره‌ی تشخیص و گراف دانش.

T1538
Cloud Service Dashboard

T1526
Cloud Service Discovery

T1619
Cloud Storage Object Di...

T1613
Container and Resource...

T1622
Debugger Evasion

T1652
Device Driver Discovery

T1680
Local Storage Discovery

T1614
System Location Discov...

T1124
System Time Discovery

T1673
Virtual Machine Discovery

T1003 OS Credential Dumping

View on attack.mitre.org [Detection chain](#) [Explore in graph](#)

RULES MAPPED TO T1003 (57)

PetitPotam Suspicious Kerberos TGT Request	Draft	Medium
Windows Mimikatz Binary Execution	Production	Medium
Windows Post Exploitation Risk Behavior	Production	Info
Detect Mimikatz With PowerShell Script Block Logging	Production	Medium
Attacker Tools On Endpoint	Production	Medium
Enable WDigest UseLogonCredential Registry	Testing	Medium
Windows Remote Access Software BRC4 Loaded DLL	Production	Medium
Windows LAPS Password Gathering Via PowerShell Script	Production	Medium
PowerShell 4104 Hunting	Production	Info
Potential LSASS Memory Dump via PssCaptureSnapshot	Production	High
Suspicious LSASS Access via MalSecLogon	Draft	High

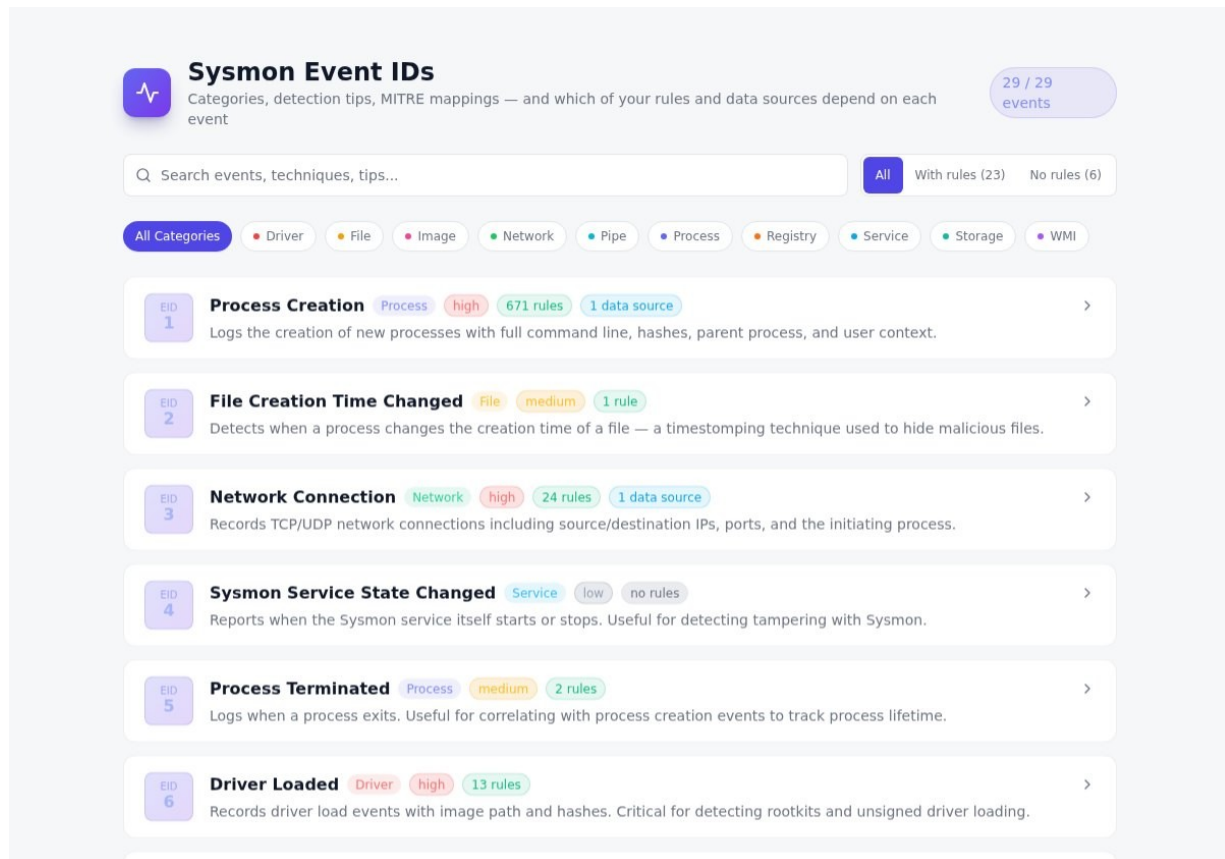
شکل ۱۹ – جزئیات تکنیک T1003 و زیرتکنیک‌های آن

نکته

MITRE گاهی شناسه‌ی تکنیک‌ها را بازنشسته و با شناسه‌ی دیگری جایگزین می‌کند. اگر قوانین شما از شناسه‌ی بازنشسته استفاده کنند، کادر آبی بالای ماتریس آن‌ها را نشان می‌دهد. سامانه این قوانین را زیر شناسه‌ی جایگزین حساب می‌کند، ولی بهتر است نداشت قانون را اصلاح کنید.

فصل ۶ – رویدادهای Sysmon

صفحه‌ی **Sysmon Events** مرجع همه‌ی رویدادهای Sysmon است. کنار هر رویداد، قوانین و منابع داده‌ای که به آن وابسته‌اند نمایش داده می‌شود.



شکل ۲۰ – فهرست رویدادهای Sysmon

- هر کارت: شماره‌ی رویداد (EID)، نام، دسته، ارزش تشخیصی (high، medium، low) و تعداد قوانین و منابع داده‌ی وابسته.
 - جست‌وجو در نام، توضیح، تکنیک‌ها و نکته‌ها. فیلتر دسته‌ها (Process، Network، Registry و ...).
 - **With rules** و **No rules**: رویدادهای دارای قانون و بدون قانون.
- با کلیک روی هر کارت، جزئیات آن باز می‌شود: فهرست قوانین وابسته (با وضعیت و شدت)، منابع داده، فیلدهای کلیدی، نکته‌های تشخیص و تکنیک‌های مرتبط. اگر قوانین زیاد باشند، اول ۵۰ قانون نمایش داده می‌شود و **Show all** بقیه را نشان می‌دهد.

Process Access Process high 44 rules 1 data source

Logs when one process opens a handle to another — key indicator for credential dumping (LSASS access).

DETECTION RULES USING THIS EVENT (44)

Access LSASS Memory for Dump Creation	Draft	Medium	auto
CMSTP Execution Process Access	Production	High	auto
Credential Dumping Activity By Python Based Tool	Draft	High	auto
Credential Dumping Attempt Via Svchost	Draft	High	auto
Credential Dumping Attempt Via WerFault	Production	High	auto
Detect Credential Dumping through LSASS access	Testing	Medium	auto
Function Call From Undocumented COM Interface EditionUpgradeManager	Deprecated	Medium	auto
HackTool - CobaltStrike BOF Injection Pattern	Testing	High	auto
HackTool - Generic Process Access	Production	High	auto
HackTool - HandleKatz Duplicating LSASS Handle	Draft	High	auto
HackTool - LittleCorporal Generated Maldoc Injection	Draft	High	auto
HackTool - SysmonEnte Execution	Production	High	auto
LSASS Access From Potentially White-Listed Processes	Production	High	auto
LSASS Memory Access by Tool With Dump Keyword In Name	Production	High	auto
Lsass Memory Dump via Comsvcs DLL	Testing	High	auto
Potential Credential Access via DuplicateHandle in LSASS	Draft	Medium	auto
Potential Credential Access via LSASS Memory Dump	Testing	High	auto
Potential Credential Dumping Activity Via LSASS	Testing	Medium	auto
Potential Direct Syscall of NtOpenProcess	Draft	Medium	auto
Potential LSASS Memory Dump via PssCaptureSnapShot	Production	High	auto
Potentially Suspicious GrantedAccess Flags On LSASS	Production	Medium	auto
Remote LSASS Process Access Through Windows Remote Management	Production	High	auto
Rubeus Kerberos Ticket Exports Through Winlogon Access	Draft	Medium	auto
Spoolsv Suspicious Process Access	Production	Medium	auto
Suspicious LSASS Access via MalSecLogon	Draft	High	auto
Suspicious LSASS Access Via MalSecLogon	Draft	High	auto
Suspicious Lsass Process Access	Draft	Medium	auto
Suspicious Process Access of MsMpEng by WerFaultSecure - EDR-Freeze	Production	High	auto
Suspicious Process Access to LSASS with Dbgcore/Dbghelp DLLs	Draft	High	auto
Suspicious Process Access via Direct System Call	Testing	High	auto
Suspicious Process Creation CallTrace	Draft	Medium	auto

شکل ۲۱ — جزئیات رویداد 10 (Process Access) و قوانین وابسته

برچسب **auto** کنار یک قانون یعنی سامانه وابستگی را خودکار از کوئری تشخیص داده است. وابستگی دستی از فرم ویرایش قانون تعیین می‌شود (فصل ۳).

فصل ۷ – ابزارهای مهاجم

صفحه‌ی **Attacker Tools** سه مرجع شناخته‌شده را نشان می‌دهد:

- **LOLBAS**: فایل‌ها، اسکریپت‌ها و کتابخانه‌های ویندوز که مهاجم از آن‌ها سوءاستفاده می‌کند.
- **GTFOBins**: فایل‌های یونیکس که برای دور زدن محدودیت‌ها استفاده می‌شوند.
- **LOLDrivers**: درایورهای آسیب‌پذیر یا مخرب ویندوز.

The screenshot shows the 'Attacker Tools' section of the DetectKB interface. It features three main categories: LOLBAS (152 / 248 covered), GTFOBins (72 / 478 covered), and LOLDrivers (386 / 697 covered). Below these are search filters and a list of tools with their descriptions and rule counts.

Tool Name	Actions	Rules
AccCheckConsole.exe	Execute, AWL Bypass	no rules
AddinUtil.exe	Execute	1 rule
adplus.exe	Dump, Execute	no rules
Advpack.dll	AWL Bypass, Execute	1 rule
AgentExecutor.exe	Execute	no rules
AppCert.exe	Execute	no rules

شکل ۲۲ – فهرست ابزارهای LOLBAS

- **کارت‌های بالا:** با کلیک روی هر کارت، مرجع مربوط انتخاب می‌شود. عدد کارت نشان می‌دهد چند ابزار دست‌کم یک قانون دارند.
 - **جست‌وجو و فیلترها:** جست‌وجو در نام و توضیح، فیلتر دسته (مثل Execute یا Download) و فیلتر دارای قانون یا بدون قانون.
 - کنار هر ابزار تعداد قوانینی که به آن اشاره کرده‌اند نمایش داده می‌شود. **no rules** یعنی هیچ قانونی آن را پوشش نمی‌دهد.
- با کلیک روی هر ابزار، جزئیات آن باز می‌شود: کاربردهای سوءاستفاده، دستور نمونه، تکنیک‌های ATT&CK، منابع و فهرست قوانینی که به آن اشاره دارند.

▼ **Certutil.exe** Download ADS Encode Decode 30 rules
Windows binary used for handling certificates

DETECTION RULES MENTIONING IT (30)

WinRAR Spawning Shell Application	Draft	Medium
Windows Suspicious React or Next.js Child Process	Draft	Medium
WinRM Spawning a Process	Production	Medium
Wscript Or Cscript Suspicious Child Process	Draft	Medium
Certutil exe certificate extraction	Testing	Medium
Windows Office Product Spawned Uncommon Process	Draft	Medium
Windows Suspicious Child Process Spawned From WebServer	Production	Medium
Windows Suspicious VMWare Tools Child Process	Draft	Medium
Windows SCCM Sxsexec Spawned a Suspicious Child Process	Testing	Medium
LOLBAS Network Connection On Uncommon Port	Production	Medium
Cisco NVM - Suspicious Download From File Sharing Website	Draft	Medium
Suspicious PDF Reader Child Process	Production	Low
Creation or Modification of Root Certificate	Production	Low
Execution via MSSQL xp_cmdshell Stored Procedure	Testing	Medium
Process Created with a Duplicated Token	Testing	Medium
Suspicious Child Process via Azure VM CustomScript Extension	Draft	Medium
Potential Execution via FileFix Phishing Attack	Draft	High
Delayed Execution via Ping	Production	Low
Suspicious Child Process of PaperCut Server Component	Draft	High
Suspicious JetBrains TeamCity Child Process	Testing	Medium
MsiExec Service Child Process With Network Connection	Deprecated	Medium
Potential IIS Web Shell File Creation	Production	High
Suspicious MS Office Child Process	Testing	Medium
Suspicious Microsoft HTML Application Child Process	Draft	High
Command Obfuscation via Unicode Modifier Letters	Production	High
Suspicious MS Outlook Child Process	Testing	Low
Suspicious Execution from a Mounted Device	Production	Medium
Suspicious CertUtil Commands	Draft	Medium
Suspicious ScreenConnect Client Child Process	Production	Medium
WMI Spawning Suspicious Child Process (Living off the Land)	Testing	High

شکل ۲۳ – جزئیات certutil.exe و قوانینی که به آن اشاره دارند

بهروزرسانی داده‌ها (مدیر)

- **Update from source:** دانلود آخرین نسخه از سایت رسمی هر مرجع. سرور باید به اینترنت دسترسی داشته باشد.

- **Upload file:** برای سرورهای بدون اینترنت. فایل JSON رسمی مرجع را روی سیستم دیگری دانلود و این‌جا بارگذاری کنید.

سامانه با مقایسه‌ی کوئری و منبع Sigma هر قانون با نام ابزارها، خودکار پیدا می‌کند کدام قانون به کدام ابزار اشاره دارد. این اطلاعات بعد از هر تغییر خودکار به‌روز می‌شود.

فصل ۸ – گراف دانش

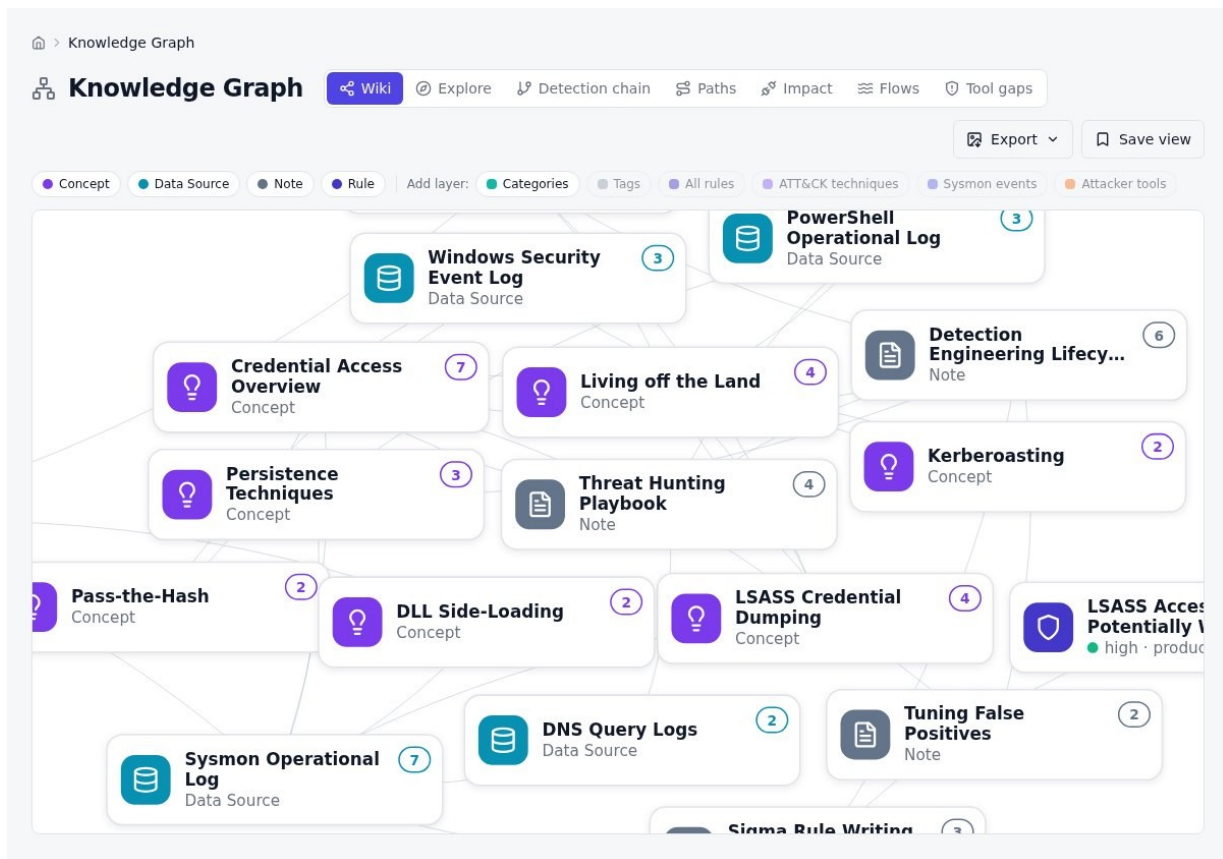
صفحه‌ی **Knowledge Graph** همه‌ی ارتباط‌ها را یک‌جا نشان می‌دهد: صفحه‌ها و لینک‌هایشان، قوانین، تکنیک‌ها، رویدادهای Sysmon، ابزارهای مهاجم، تگ‌ها و دسته‌ها. گراف هفت نما دارد که با تب‌های بالای صفحه انتخاب می‌شوند:

نما	کاربرد
Wiki	صفحه‌های دانش و لینک‌های بین آن‌ها.
Explore	شروع از یک گره و باز کردن قدم‌به‌قدم همسایه‌ها.
Detection chain	زنجیره‌ی یک تکنیک: تاکتیک ← تکنیک ← قوانین ← رویدادها ← منابع داده.
Paths	کوتاه‌ترین مسیرهای ارتباطی بین دو گره.
Impact	اگر یک منبع داده یا رویداد قطع شود، چه چیزی از کار می‌افتد.
Flows	جریان تشخیص‌ها از رویدادهای Sysmon به تاکتیک‌های ATT&CK.
Tool gaps	ابزارهای مهاجم و تکنیک‌هایی که هیچ قانونی پوششان نمی‌دهد.

وضعیت هر نما در آدرس صفحه ذخیره می‌شود؛ می‌توانید آن را با **Save view** ذخیره کنید یا لینکش را بفرستید.

Wiki

صفحه‌های دانش و لینک‌های ویکی بینشان نمایش داده می‌شوند. هر رنگ یک نوع صفحه است. با چرخ ماوس بزرگ‌نمایی کنید و با کشیدن، گراف را جابه‌جا کنید. با کلیک روی هر گره، پنل جزئیات آن باز می‌شود. با دکمه‌های لایه‌ها می‌توانید قوانین، تکنیک‌ها، رویدادها، ابزارها، تگ‌ها و دسته‌ها را هم به گراف اضافه کنید.

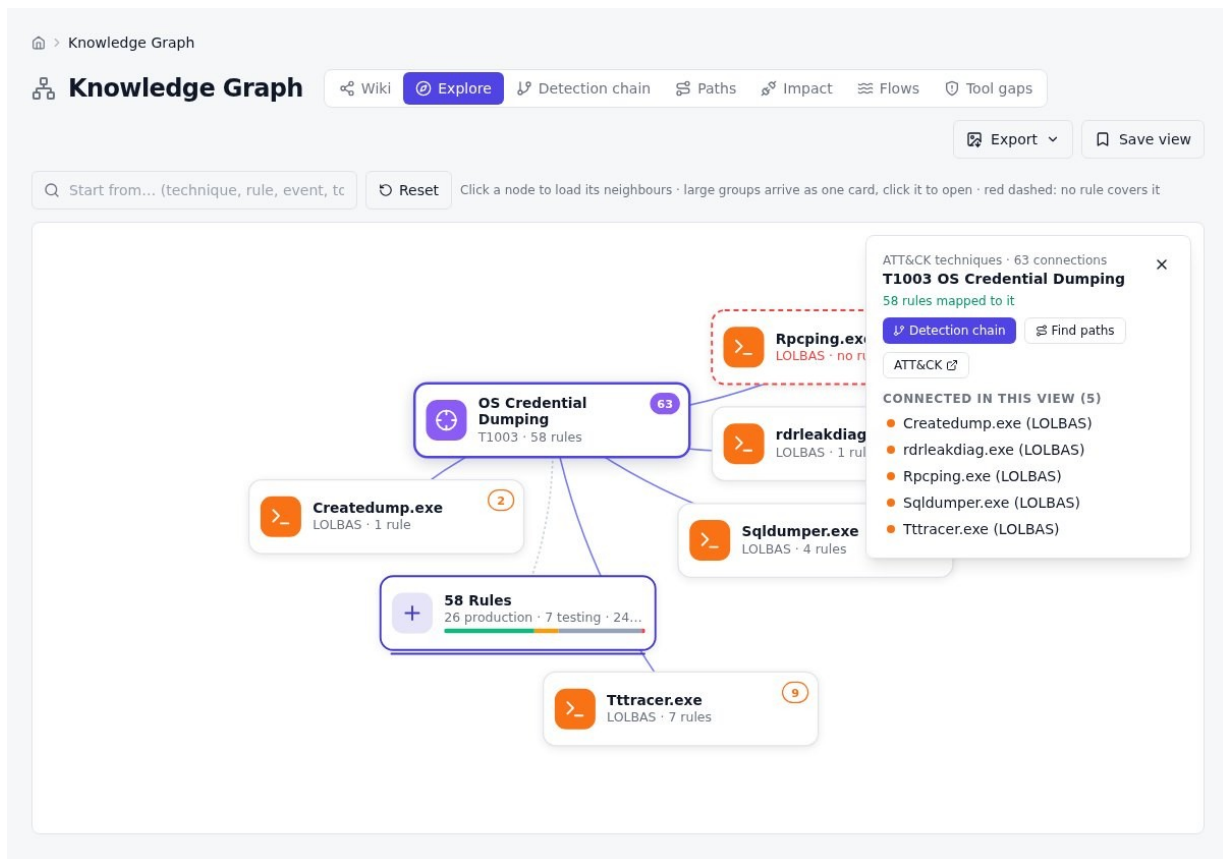


شکل ۲۴ – نمای Wiki

Explore

مناسب‌ترین نما برای کاوش. یک نقطه‌ی شروع انتخاب کنید: در جعبه‌ی **Start from**... جست‌وجو کنید یا یکی از گره‌های پیشنهادی را بزنید. سپس:

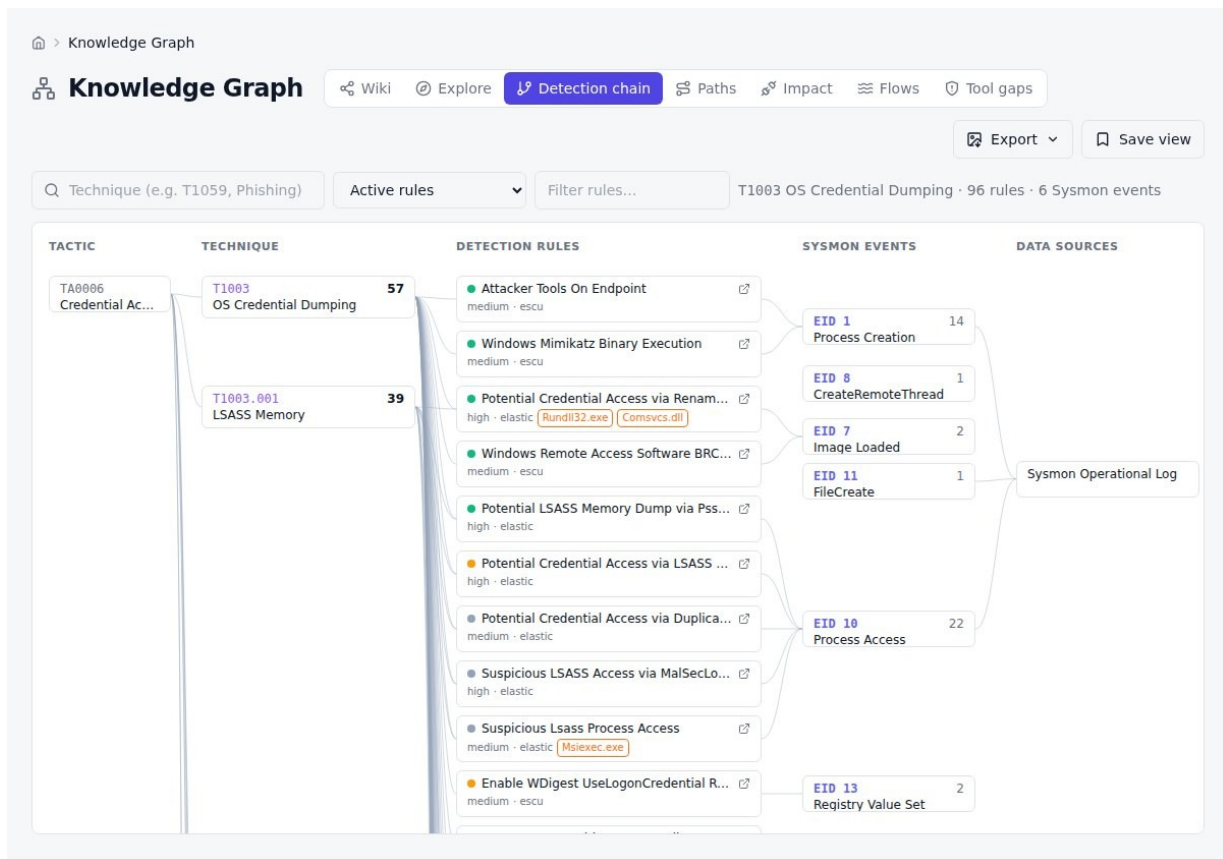
- با کلیک روی هر کارت، همسایه‌هایش بار می‌شوند. عدد گوشه‌ی کارت تعداد کل ارتباط‌های آن است.
- گروه‌های بزرگ، مثلاً ۵۸ قانون یک تکنیک، به شکل یک **کارت گروهی** با نوار وضعیت نمایش داده می‌شوند. با کلیک روی کارت، اعضا ۲۵ تا ۲۵ تا باز می‌شوند.
- کارت با **خط‌چین قرمز** و عبارت **no rules** یعنی ابزار یا تکنیکی که هیچ قانونی پوششش نمی‌دهد: یک شکاف تشخیص.
- در پنل کنار گراف: **Detection chain** زنجیره‌ی تکنیک، **Find paths** یافتن مسیر از این گره، **Start from here** شروع دوباره از این گره، و **Hide** پنهان کردن گره.
- **Reset** گراف را به نقطه‌ی شروع برمی‌گرداند.



شکل ۲۵ – نمای Explore حول تکنیک T1003

Detection chain

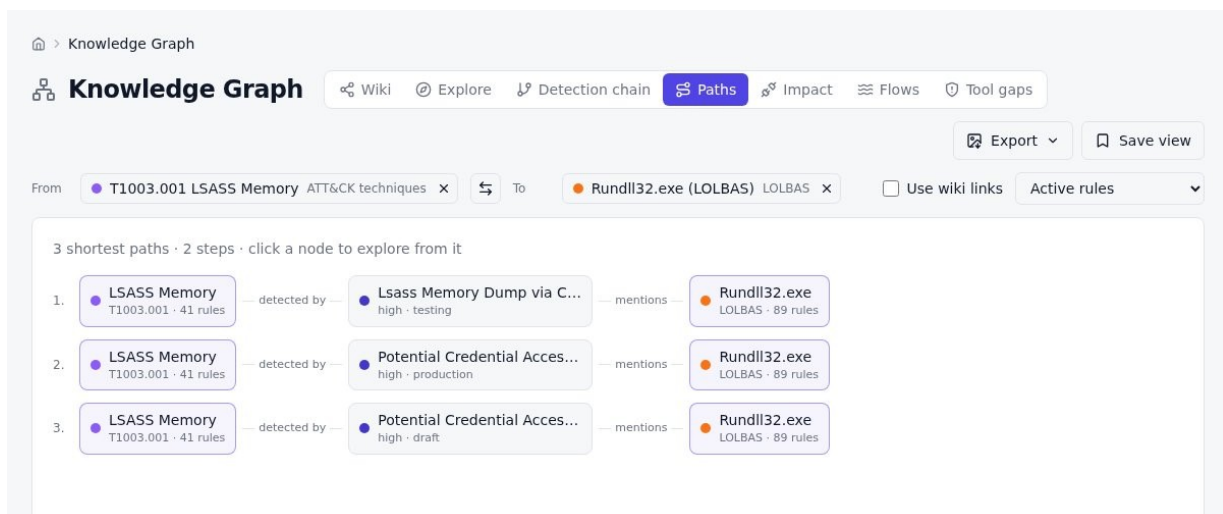
یک تکنیک را انتخاب کنید تا زنجیره‌ی کامل تشخیص آن در ستون‌ها نمایش داده شود: تاکتیک‌ها، تکنیک و زیرتکنیک‌ها، قوانین، رویدادهای Sysmon و منابع داده. ابزارهای مهاجمی که قوانین به آن‌ها اشاره دارند هم نشان داده می‌شوند. ماوس را روی هر مورد ببرید تا مسیر آن پررنگ شود؛ با کلیک، مسیر ثابت می‌ماند. فیلتر وضعیت و جست‌وجو در قوانین هم بالای صفحه است.



شکل ۲۶ – زنجیره‌ی تشخیص T1003

Paths

دو گره را در **From** و **To** انتخاب کنید. سامانه کوتاه‌ترین مسیرهای بینشان را نشان می‌دهد، مثلاً «این ابزار از طریق کدام قوانین به این تکنیک می‌رسد؟». روی هر قدم نوع رابطه نوشته شده است، مثل **detects** (قانون، تکنیک را تشخیص می‌دهد) یا **mentions** (قانون به ابزار اشاره می‌کند). با کلیک روی هر گره مسیر، نمای Explore از آن گره شروع می‌شود. دکمه‌ی **↶** مبدأ و مقصد را جابه‌جا می‌کند.



شکل ۲۷ – مسیرهای بین T1003.001 و rundll32.exe

مسیرها فقط از روابط مدل تشخیص می‌گذرند:

- ابزار – تکنیکی که برای آن به کار می‌رود (نگاشت LOLBAS و LOLDrivers)
- قانون – تکنیکی که تشخیص می‌دهد، و ابزاری که در متنش آمده
- قانون – رویداد Sysmon – منبع داده‌ای که آن رویداد را فراهم می‌کند
- زیرتکنیک – تکنیک والد

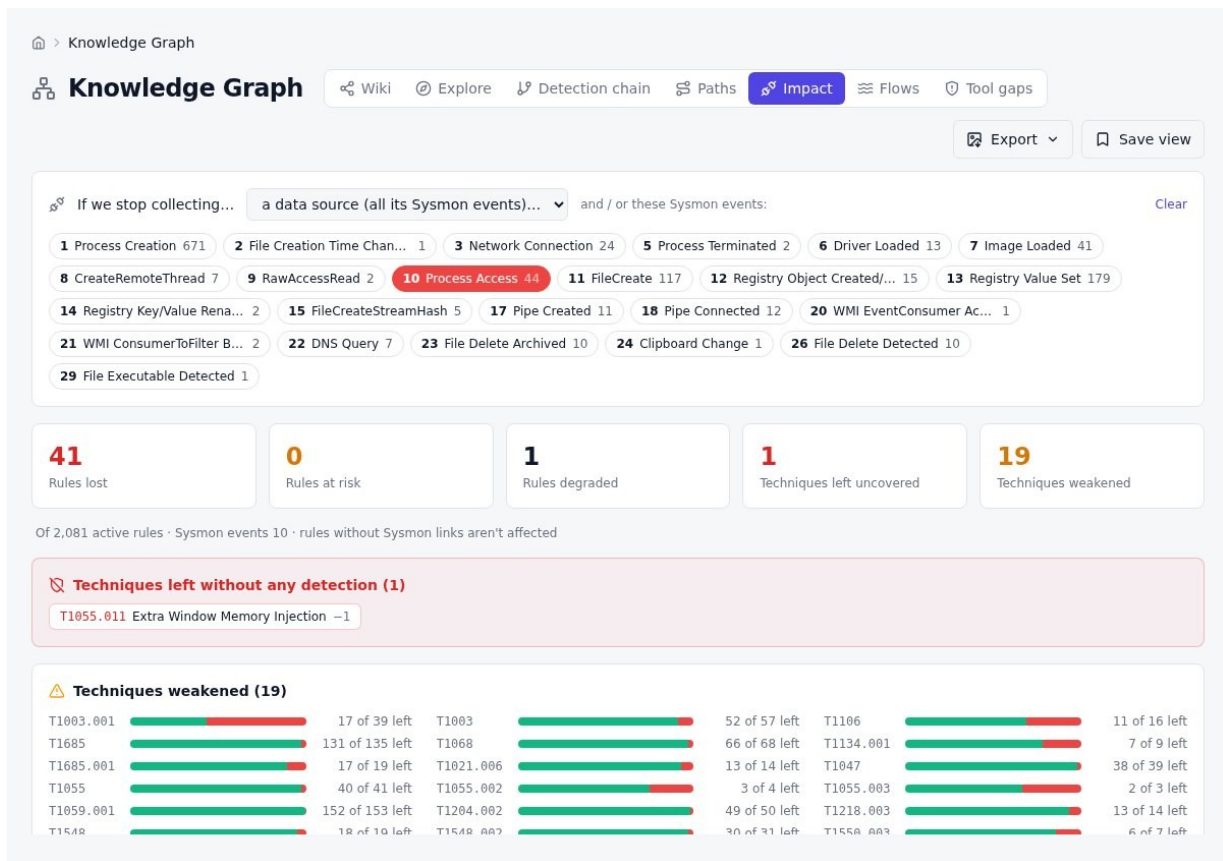
چند قاعده برای معتبر ماندن مسیرها:

- تگ‌ها و دسته‌ها هیچ‌وقت گره میانی نیستند.
- رویداد Sysmon فقط یک قانون را به یک منبع داده وصل می‌کند. دو قانونی که هر دو از یک رویداد استفاده می‌کنند، به این دلیل به هم مرتبط حساب نمی‌شوند.
- قوانین deprecated به‌طور پیش‌فرض کنار گذاشته می‌شوند. با منوی وضعیت بالای صفحه می‌توانید فقط Production، Production + testing یا همه را انتخاب کنید.
- لینک‌های ویکی و صفحات Concept و Note فقط با گزینه **Use wiki links** در مسیر می‌آیند. خود گره‌هایی که انتخاب کرده‌اید همیشه می‌توانند از لینک‌هایشان استفاده کنند. اگر مسیری پیدا نشود ولی با لینک‌های ویکی پیدا شود، سامانه پیشنهادش را می‌دهد.
- از بین کوتاه‌ترین مسیرها، مسیرهایی انتخاب می‌شوند که کمترین هم‌پوشانی را داشته باشند، تا حداکثر ۸ مسیر متفاوت ببینید.

Impact – تحلیل اثر

برای جواب دادن به این سؤال: «اگر جمع‌آوری این داده قطع شود، چه چیزی از دست می‌رود؟»

1. از منوی **If we stop collecting...** یک منبع داده انتخاب کنید (همه‌ی رویدادهای Sysmon آن حساب می‌شوند)، یا روی رویدادهای مورد نظر کلیک کنید.
2. نتیجه فوراً نمایش داده می‌شود.



شکل ۲۸ – تحلیل اثر قطع رویداد 10

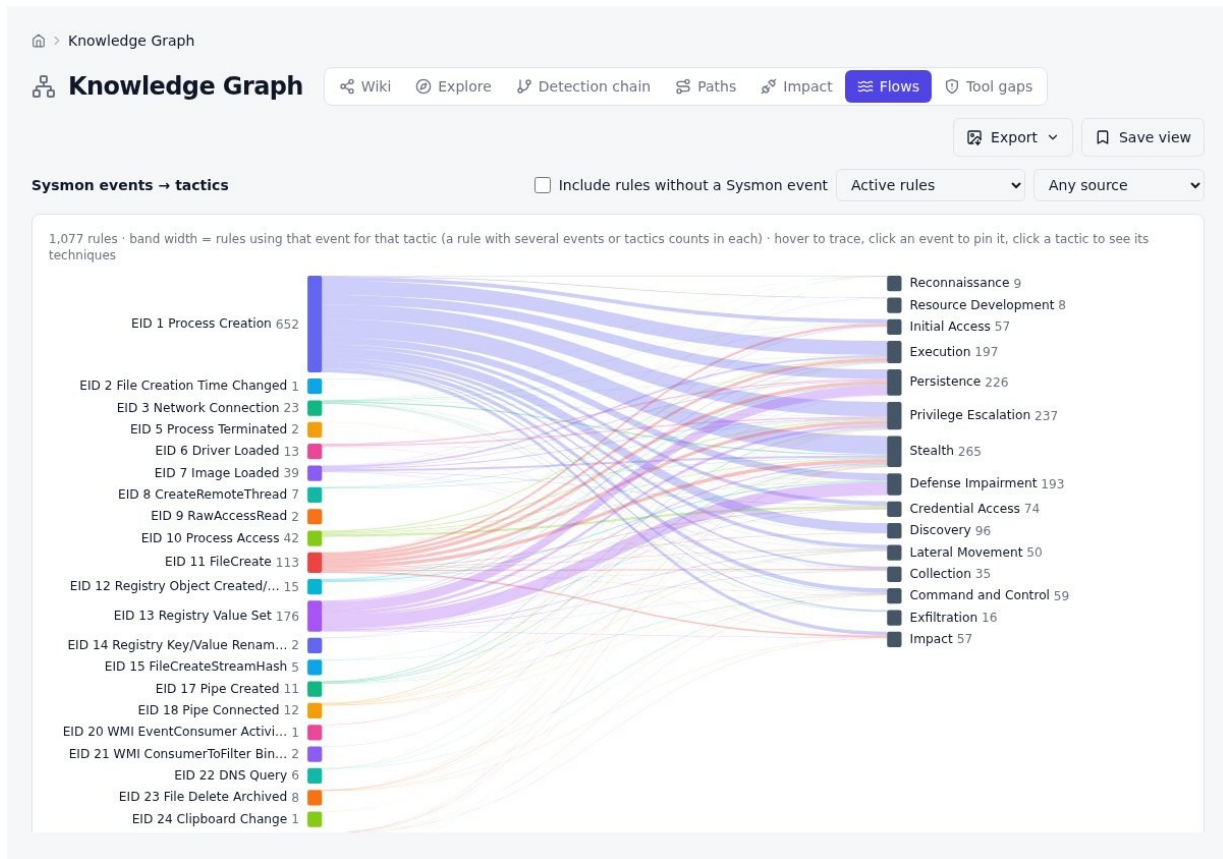
نتیجه	معنی
Rules lost	همه‌ی رویدادهای Sysmon قانون قطع شده و منبع دیگری هم برایش ثبت نشده است.
Rules at risk	همه‌ی رویدادهای Sysmon قانون قطع شده، ولی منبع دیگری هم در قانون ذکر شده که شاید هنوز کار کند.
Rules degraded	بخشی از رویدادهای Sysmon قانون قطع شده است.
Techniques left uncovered	تکنیک‌هایی که همه‌ی قوانینشان از دست می‌رود. با کلیک، زنجیره‌ی تشخیص آن‌ها باز می‌شود.
Techniques weakened	تکنیک‌هایی که بخشی از قوانینشان را از دست می‌دهند. نوار رنگی سهم باقی‌مانده، در خطر و از دست رفته را نشان می‌دهد.

نکته

تحلیل اثر فقط وابستگی قوانین به رویدادهای Sysmon را می‌شناسد. قوانینی که به هیچ رویداد Sysmon وصل نیستند، مثل قوانین متکی به Security Log یا EDR، در این محاسبه نیستند.

Flows – نمودار جریان

هر نوار نشان می‌دهد چند قانون از یک رویداد Sysmon (سمت چپ) برای یک تاکتیک ATT&CK (سمت راست) استفاده می‌کنند. پهنای نوار متناسب با تعداد قوانین است. با این نمودار معلوم می‌شود تشخیص هر تاکتیک به کدام داده متکی است.

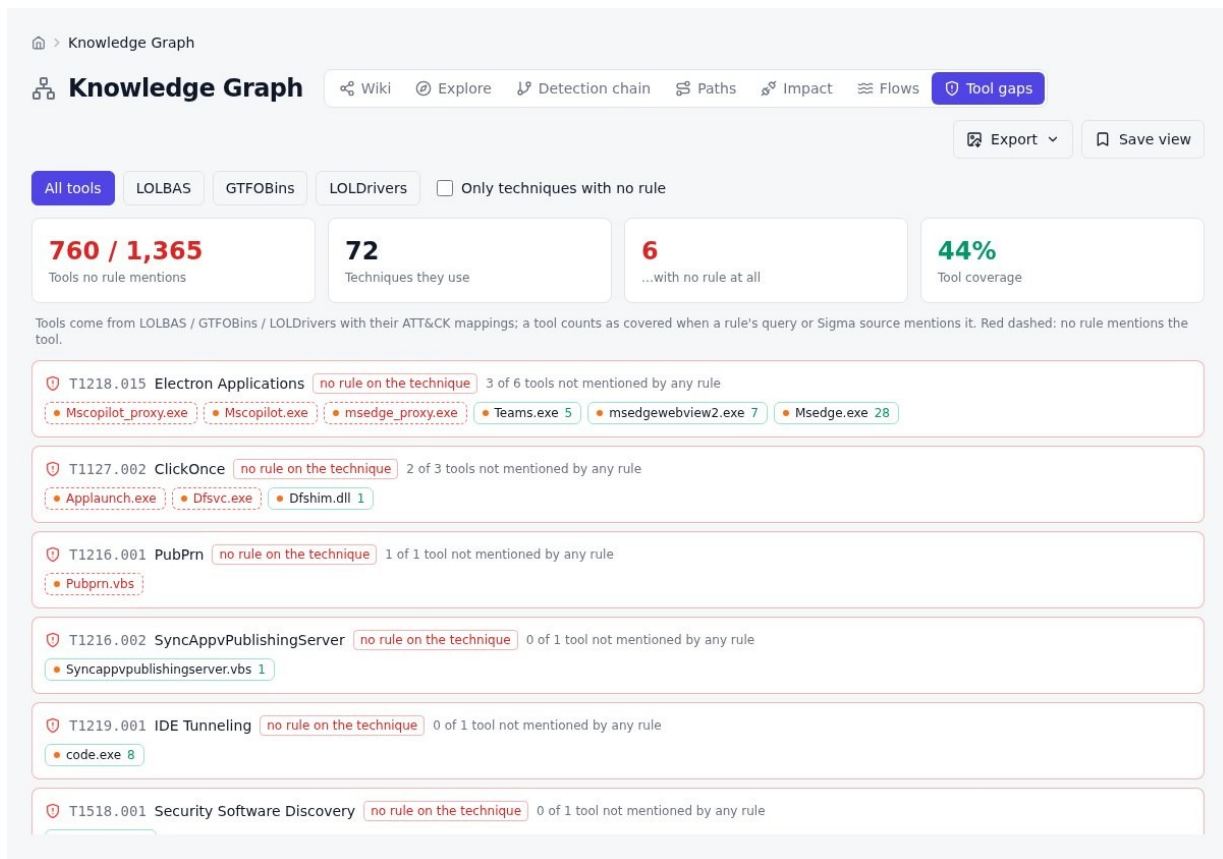


شکل ۲۹ – نمودار جریان از رویدادهای Sysmon به تاکتیک‌ها

- ماوس را روی یک رویداد یا تاکتیک ببرید تا جریان‌های آن پررنگ شود.
- با کلیک روی یک تاکتیک، نمودار به تکنیک‌های همان تاکتیک می‌رسد. با کلیک روی یک تکنیک، زنجیره‌ی تشخیص آن باز می‌شود.
- با کلیک روی یک رویداد، **What if we lose it?** تحلیل اثر همان رویداد را باز می‌کند.
- فیلترهای بالا: وضعیت قوانین، منبع قوانین، و **Include rules without a Sysmon event** برای افزودن قوانینی که رویداد Sysmon ندارند.

Tool gaps – شکاف ابزارها

این نما تکنیک‌هایی را فهرست می‌کند که ابزارهای شناخته‌شده‌ی مهاجم دارند، همراه با ابزارهایی که هیچ قانونی به آن‌ها اشاره نمی‌کند. تکنیک‌هایی که اصلاً قانون ندارند با آیکون هشدار و کادر قرمز، بالای فهرست قرار می‌گیرند.

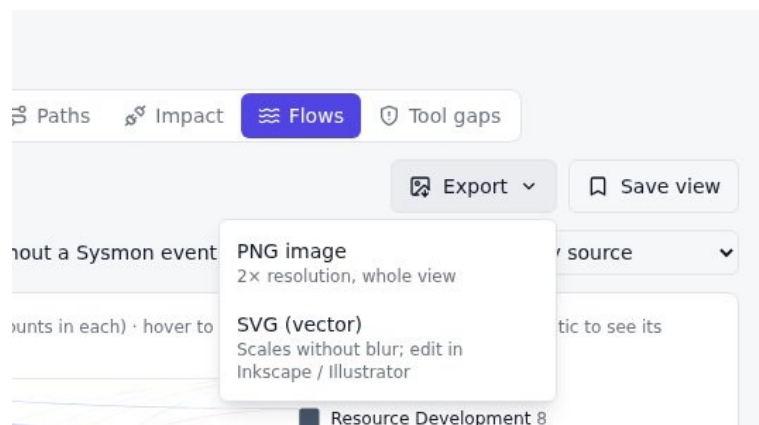


شکل ۳۰ - نمای Tool gaps

- ابزارهای خطچین قرمز در هیچ قانونی نیامده‌اند و ابزارهای سبز قانون دارند (با تعداد).
- فیلتر مرجع: **All tools**، **LOLBAS**، **GTF0Bins**، **LOLDrivers**. گزینه **Only techniques with no rule** فقط تکنیک‌های بدون قانون را نشان می‌دهد.
- با کلیک روی تکنیک، نمای Explore از آن شروع می‌شود و با کلیک روی ابزار، صفحه‌ی ابزار باز می‌شود.

خروجی تصویر

دکمه‌ی **Export** بالای گراف، نمای فعلی را ذخیره می‌کند:



شکل ۳۱ - منوی خروجی گراف

- **PNG image**: تصویر با وضوح دوبرابر از کل نما، حتی بخش‌هایی که دیده نمی‌شوند. برای همه‌ی نماها.
- **SVG (vector)**: تصویر برداری که بدون افت کیفیت بزرگ می‌شود. فقط برای نمای Flows.

فصل ۹ – صفحات دانش

غیر از قوانین، سامانه صفحه‌های دانش هم دارد: مفاهیم (**Concept**)، منابع داده (**Data Source**)، یادداشت‌ها (**Note**) و دستورهای SPL. همه با Markdown نوشته می‌شوند و با لینک ویکی به هم وصل‌اند.

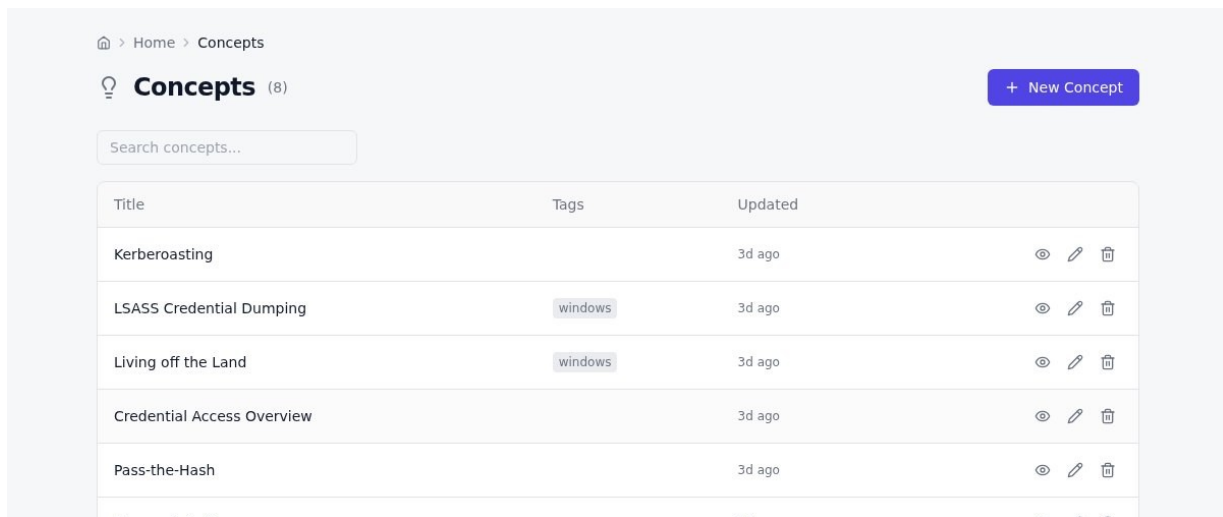
فهرست همه‌ی صفحه‌ها

صفحه‌ی **All Pages** همه‌ی صفحه‌ها، از جمله قوانین، را نشان می‌دهد.

Title	Type	Tags	Updated
Kerberoasting	Concept		3d ago
LSASS Credential Dumping	Concept	windows	3d ago
Living off the Land	Concept	windows	3d ago
Sysmon Operational Log	Data Source	windows	3d ago
Detection Engineering Lifecycle	Note	guide	3d ago
Sigma Rule Writing Guide	Note	guide	3d ago
Atomic Red Team Testing	Note	guide	3d ago
Tuning False Positives	Note	guide	3d ago
Credential Access Overview	Concept		3d ago
Pass-the-Hash	Concept		3d ago
Process Injection	Concept		3d ago
DLL Side-Loading	Concept		3d ago

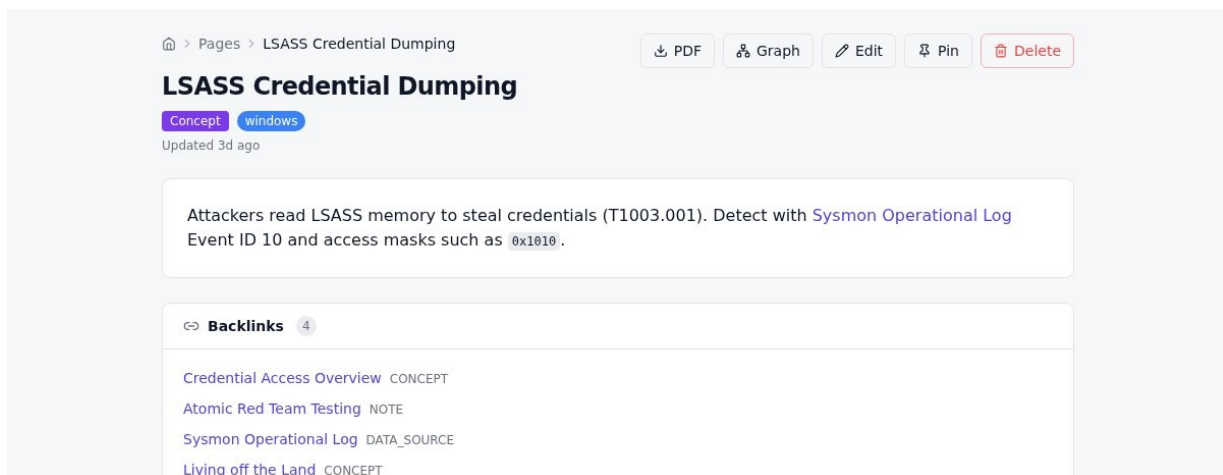
شکل ۳۲ – فهرست همه‌ی صفحه‌ها

- **دکمه‌های نوع:** فیلتر بر اساس نوع صفحه. عدد کنار هر نوع، تعداد صفحه‌های آن است.
 - **تگ‌ها:** فیلتر بر اساس تگ. پرکاربردترین تگ‌ها اول می‌آیند و بقیه پشت **more**.
 - **جست‌وجو:** در عنوان و متن صفحه‌ها.
 - مرتب‌سازی با کلیک روی سر ستون‌ها (عنوان، نوع، تاریخ)، و صفحه‌بندی پایین جدول.
 - دکمه‌های هر ردیف: مشاهده، ویرایش و حذف.
- صفحه‌های **Concepts** و **Data Sources** در نوار کناری همین فهرست‌اند، ولی فقط برای یک نوع صفحه.



شکل ۳۳ – فهرست مفاهیم

مشاهده‌ی صفحه



شکل ۳۴ – صفحه‌ی یک مفهوم با لینک ویکی و فهرست Backlinks

- لینک‌های ویکی با رنگ آبی نمایش داده می‌شوند و صفحه‌ی مقصد را باز می‌کنند. لینکی که صفحه‌اش وجود ندارد با رنگ دیگری نمایش داده می‌شود و با کلیک، ساخت آن صفحه شروع می‌شود.
- **Backlinks**: صفحه‌هایی که به این صفحه لینک داده‌اند.
- دکمه‌های بالا مثل صفحه‌ی قانون است: **Delete**، **PDF**، **Graph**، **Edit**، **Pin**.

ساخت و ویرایش صفحه

1. **New Page** را در نوار بالا بزنید، یا در فهرست Concepts و Data Sources دکمه‌ی ساخت همان نوع را.
2. عنوان، نوع، دسته و تگ‌ها را وارد کنید.
3. متن را در کادر **Content** با Markdown بنویسید.
4. **Save** را بزنید.

لینک ویکی: برای لینک به صفحه‌ی دیگر، [] تایپ کنید و چند حرف از عنوان صفحه را بنویسید. فهرست پیشنهادها باز می‌شود؛ با کلیدهای جهت‌دار انتخاب و با **Enter** درج کنید. نتیجه به شکل `[[عنوان صفحه]]` در متن قرار می‌گیرد.

The screenshot shows the 'Edit Page' interface for a page titled 'LSASS Credential Dumping'. The page has a 'Type' dropdown set to 'Concept', a 'Category' dropdown set to 'None', and 'Tags' set to 'windows'. The 'Content' area contains a paragraph about attackers reading LSASS memory to steal credentials (T1003.001) and a 'Wiki link' dropdown menu showing suggestions like 'LSASS Memory Access by Tool With Dump Keyword In Name'.

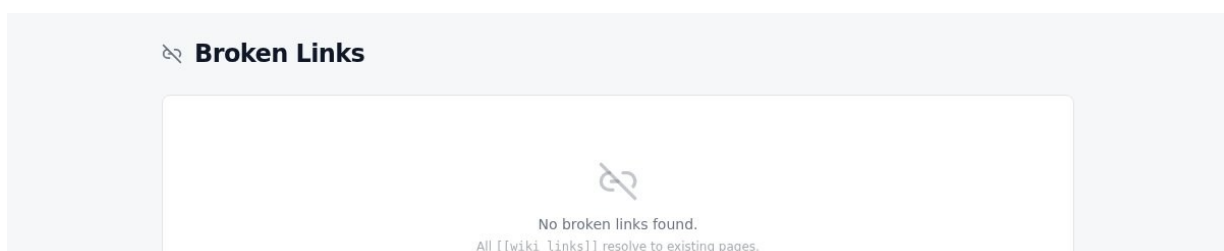
شکل ۳۵ – پیشنهاد صفحه هنگام نوشتن لینک ویکی

دسته‌بندی‌ها

در نوار کناری، کنار **Categories**، دکمه‌ی + را بزنید، نام و رنگ دسته را انتخاب کنید و ذخیره کنید. با کلیک روی نام دسته، صفحه‌های آن نمایش داده می‌شوند. دسته‌ی هر صفحه در فرم ویرایش آن تعیین می‌شود. با حذف یک دسته، صفحه‌هایش حذف نمی‌شوند و فقط بدون دسته می‌مانند.

لینک‌های شکسته

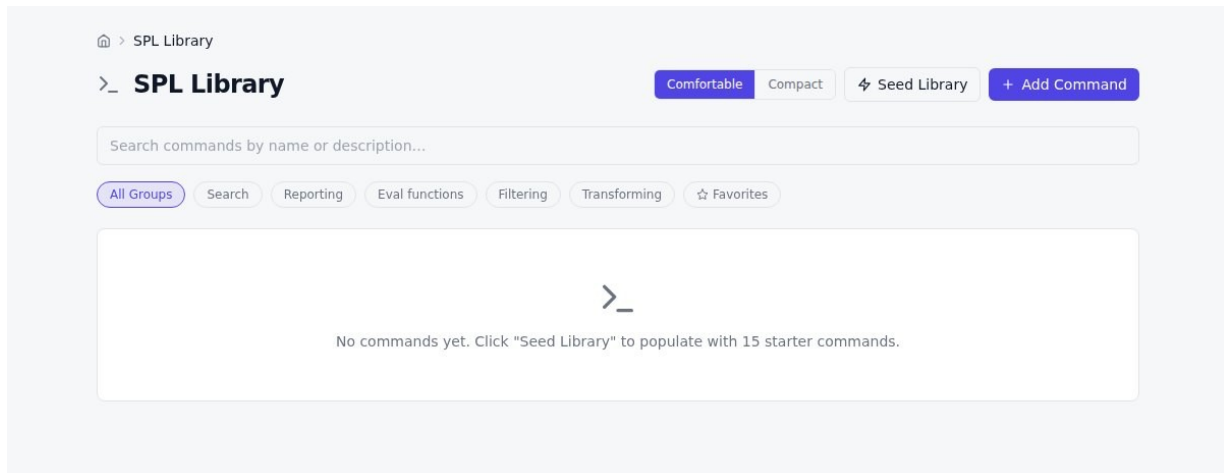
صفحه‌ی **Broken Links** همه‌ی لینک‌های ویکی را که به صفحه‌ی ناموجود اشاره می‌کنند فهرست می‌کند، همراه با صفحه‌ای که لینک در آن است. آن‌ها را اصلاح کنید یا صفحه‌ی مقصد را بسازید.



شکل ۳۶ – صفحه‌ی لینک‌های شکسته (در این نمونه لینک شکسته‌ای وجود ندارد)

کتابخانه‌ی SPL

صفحه‌ی **SPL Library** مجموعه‌ای از دستورهای پرکاربرد Splunk با نحو، توضیح، مثال و نکته‌هاست. با **Add Command** دستور جدید اضافه می‌شود. **Seed Library** مجموعه‌ی آغازینی از ۱۵ دستور رایج را اضافه می‌کند. فیلتر گروه‌ها (Search، Reporting، Eval functions و ...)، علامت‌گذاری علاقه‌مندی‌ها و دو حالت نمایش هم هست.

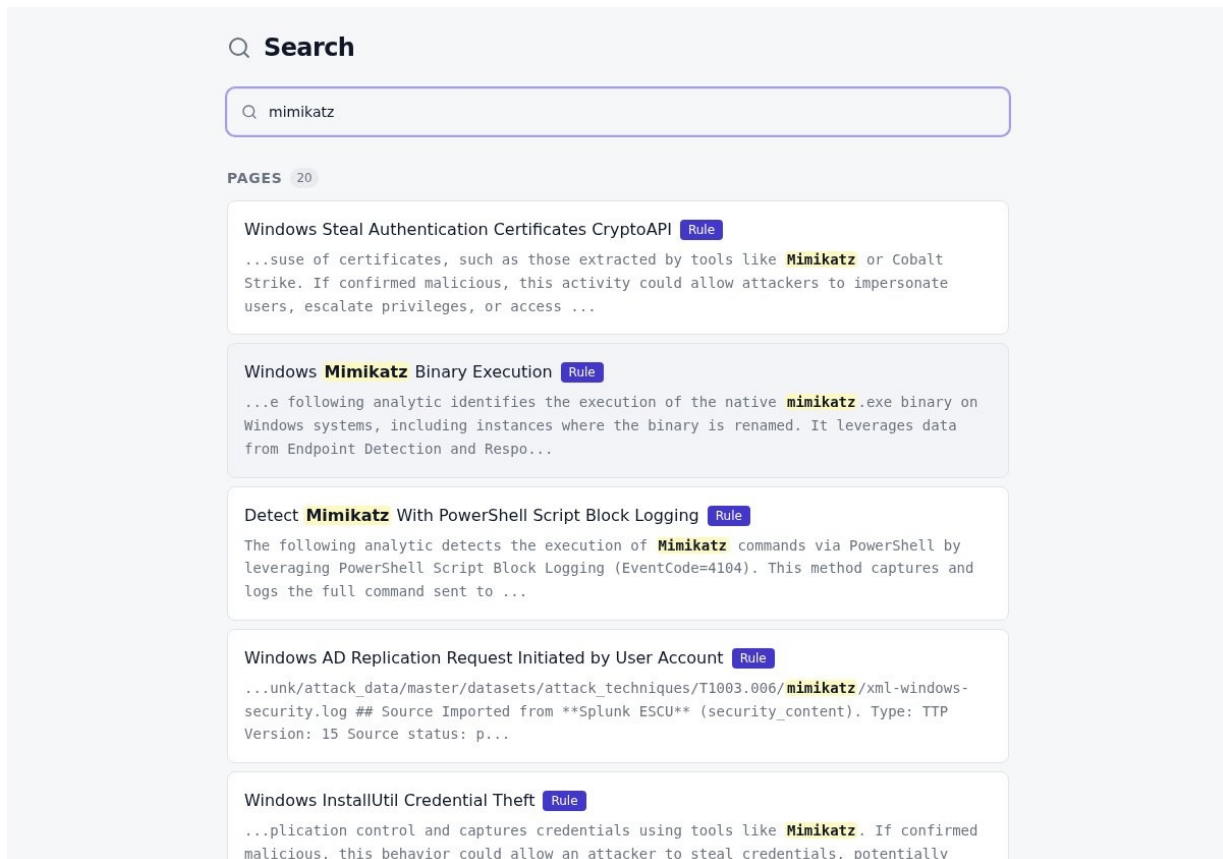


شکل ۳۷ – کتابخانه‌ی SPL

فصل ۱۰ – جست‌وجو و مستندسازی

جست‌وجو

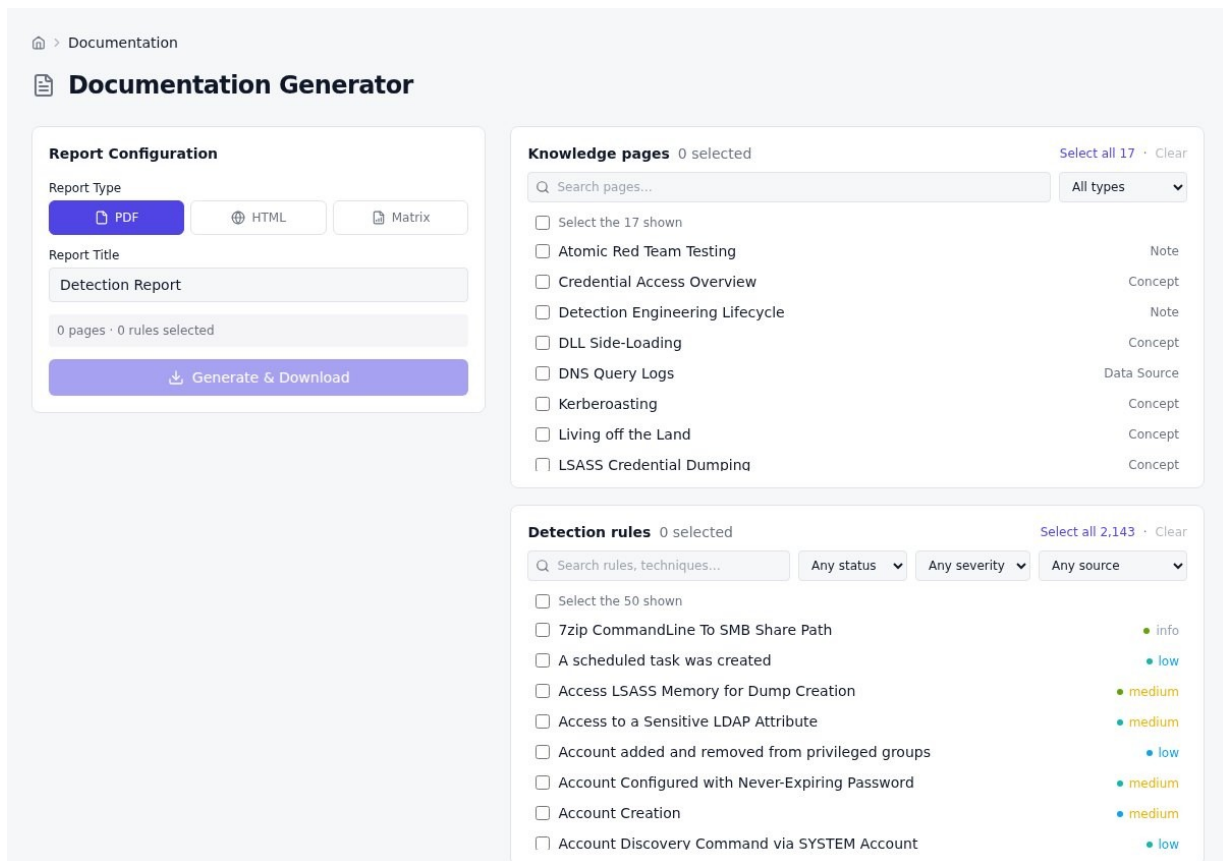
صفحه‌ی **Search** در عنوان و متن همه‌ی صفحه‌ها و قوانین جست‌وجو می‌کند. کلمه‌ی جست‌وجو شده در نتیجه‌ها پررنگ می‌شود و نوع هر نتیجه کنار عنوانش نمایش داده می‌شود. برای جست‌وجوی سریع در هر صفحه، **Ctrl+K** را بزنید (فصل ۲).



شکل ۳۸ – نتیجه‌ی جست‌وجوی mimikatz

ساخت گزارش

صفحه‌ی **Documentation** از صفحه‌ها و قوانین انتخاب‌شده گزارش می‌سازد.



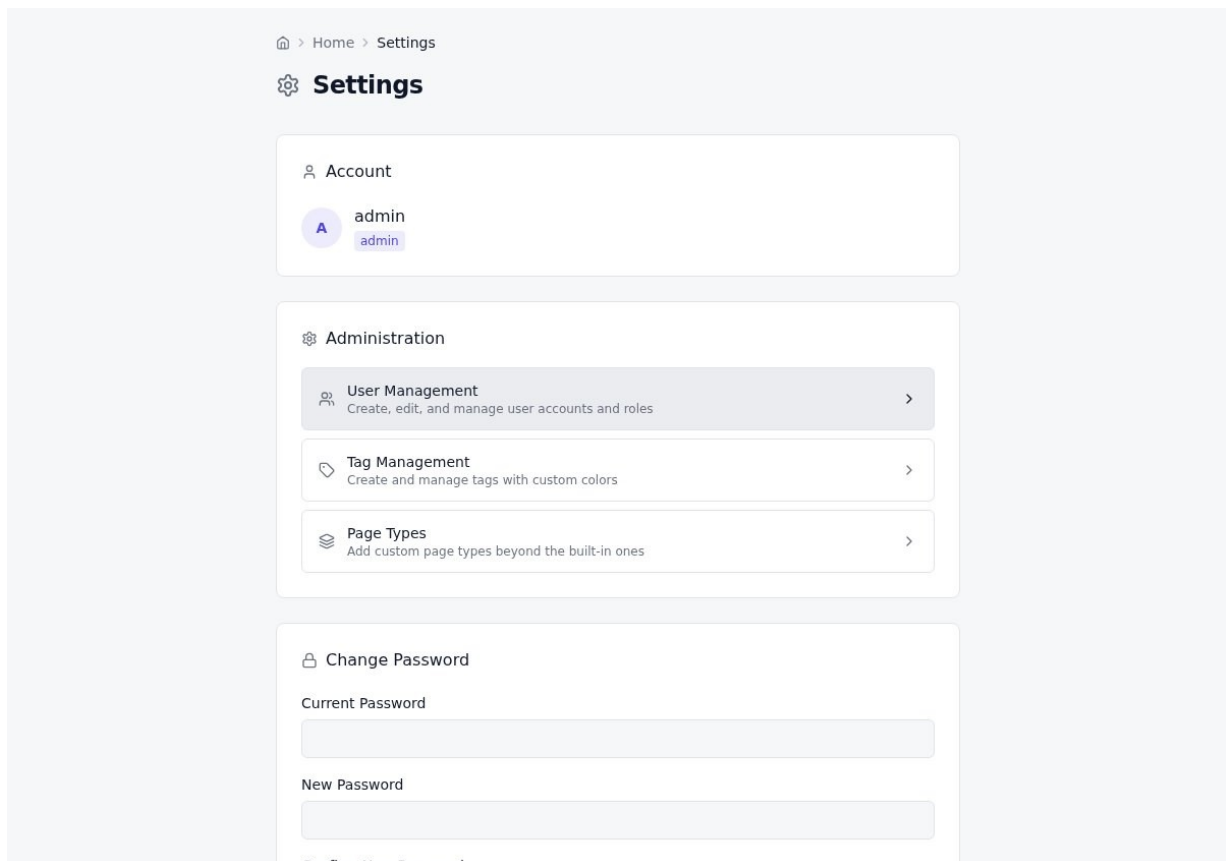
شکل ۳۹ – صفحه‌ی ساخت گزارش

1. نوع گزارش را انتخاب کنید: **HTML**، **PDF** (با فهرست مطالب اختیاری) یا **Matrix** (ماتریس تشخیص بر اساس تکنیک و شدت، با فیلتر تگ اختیاری).
 2. عنوان گزارش را بنویسید.
 3. در **Knowledge pages** و **Detection rules** موارد مورد نظر را انتخاب کنید. هر دو فهرست جست‌وجو و فیلتر دارند (قوانین با وضعیت، شدت و منبع). **Select all N matching** همه‌ی موارد منطبق با فیلتر را یکجا انتخاب می‌کند و **Show more** موارد بیشتری نشان می‌دهد.
 4. **Generate & Download** را بزنید. گزارش ساخته و دانلود می‌شود.
- گزارش‌های ساخته‌شده در جدول **Generated Documents** پایین صفحه می‌مانند و از آن‌جا دوباره دانلود یا حذف می‌شوند.

فصل ۱۱ – مدیریت سامانه

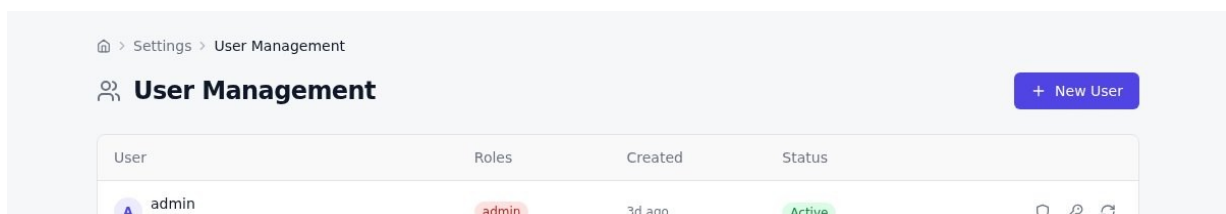
تنظیمات و تغییر رمز

صفحه‌ی **Settings** اطلاعات حساب شما را نشان می‌دهد. در بخش **Change Password** رمز فعلی و رمز جدید را وارد کنید و ذخیره کنید. مدیر در بخش **Administration** به مدیریت کاربران، تگ‌ها و انواع صفحه دسترسی دارد.



شکل ۴۰ – صفحه‌ی تنظیمات

مدیریت کاربران (مدیر)



شکل ۴۱ – فهرست کاربران

- **New User**: ساخت کاربر جدید با نام کاربری، ایمیل، رمز اولیه و نقش. کاربر در اولین ورود باید رمزش را عوض کند.

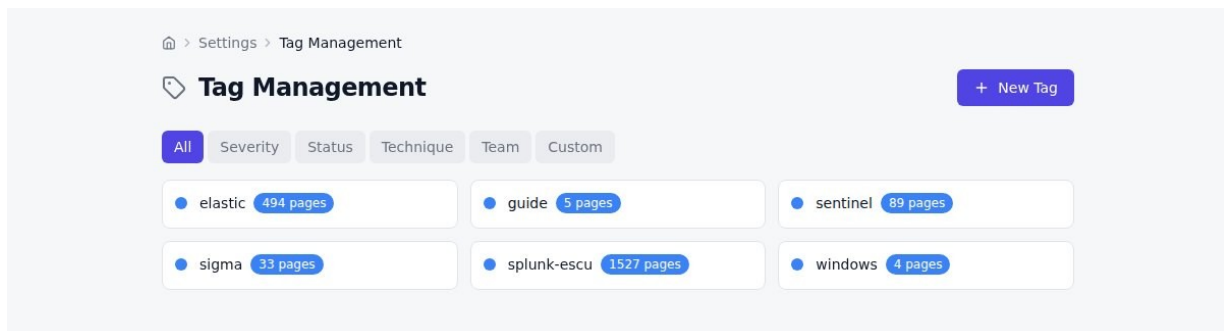
- دکمه‌های کنار هر کاربر: **Edit roles** تغییر نقش‌ها، **Reset password** تعیین رمز جدید (کاربر باید دوباره آن را عوض کند)، و **Disable user / Enable user** غیرفعال یا فعال کردن حساب.

نکته

به جای حذف کاربری که دیگر نباید وارد شود، حسابش را غیرفعال کنید. سوابق فعالیت او در گزارش فعالیت حفظ می‌شود.

تگ‌ها

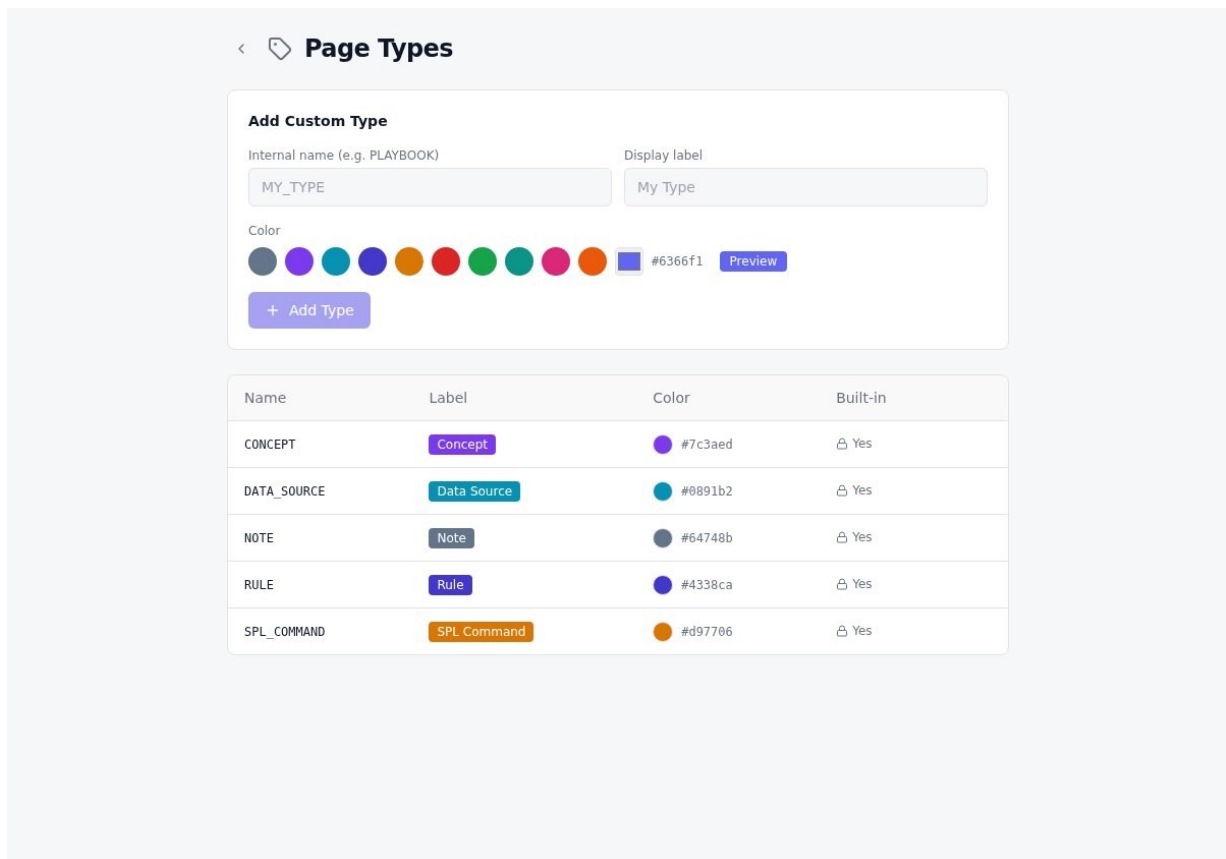
صفحه‌ی **Tag Management** همه‌ی تگ‌ها را با تعداد صفحه‌های هر کدام نشان می‌دهد. با **New Tag** تگ جدید با رنگ و دسته‌ی دلخواه ساخته می‌شود و می‌توانید تگ‌ها را ویرایش یا حذف کنید. تگ‌ها بر اساس دسته (Severity، Status، Technique، Team، Custom) فیلتر می‌شوند.



شکل ۴۲ – مدیریت تگ‌ها

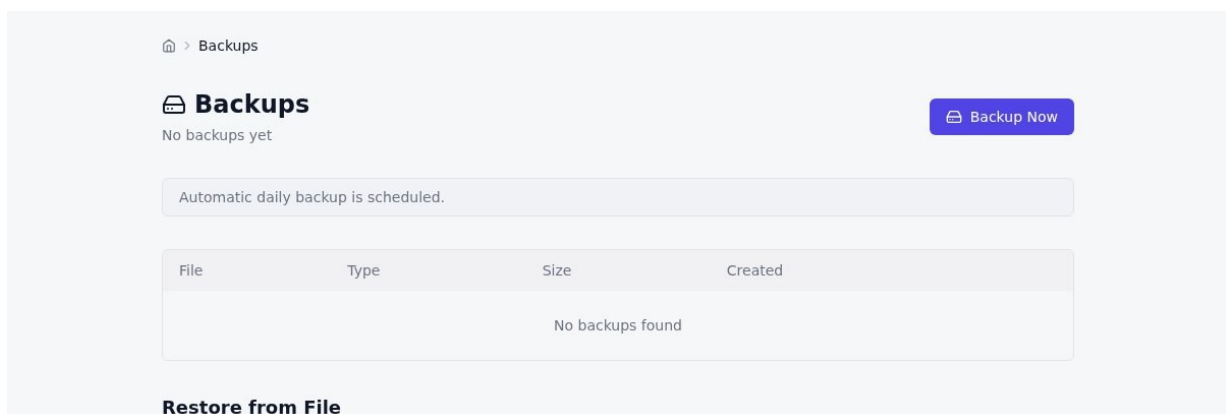
انواع صفحه (مدیر)

غیر از پنج نوع پیش‌فرض (Concept، Data Source، Note، Rule، SPL Command)، می‌توانید نوع دلخواه بسازید، مثلاً Playbook برای روال‌های پاسخ به رخداد. در **Add Custom Type** نام داخلی (حروف بزرگ انگلیسی)، برچسب نمایشی و رنگ را تعیین کنید و **Add Type** را بزنید.



شکل ۴۳ – انواع صفحه

پشتیبان‌گیری و بازگردانی



شکل ۴۴ – صفحه‌ی پشتیبان‌گیری

- **Backup Now:** پشتیبان کامل از پایگاه دانش در قالب JSON. فایل در فهرست پایین صفحه قرار می‌گیرد و قابل دانلود است.
- سامانه روزانه یک پشتیبان خودکار هم می‌گیرد.
- **Restore from File:** با **Choose JSON file** فایل پشتیبان را انتخاب و **Restore** را بزنید. این کار فقط برای مدیر است.

توجه

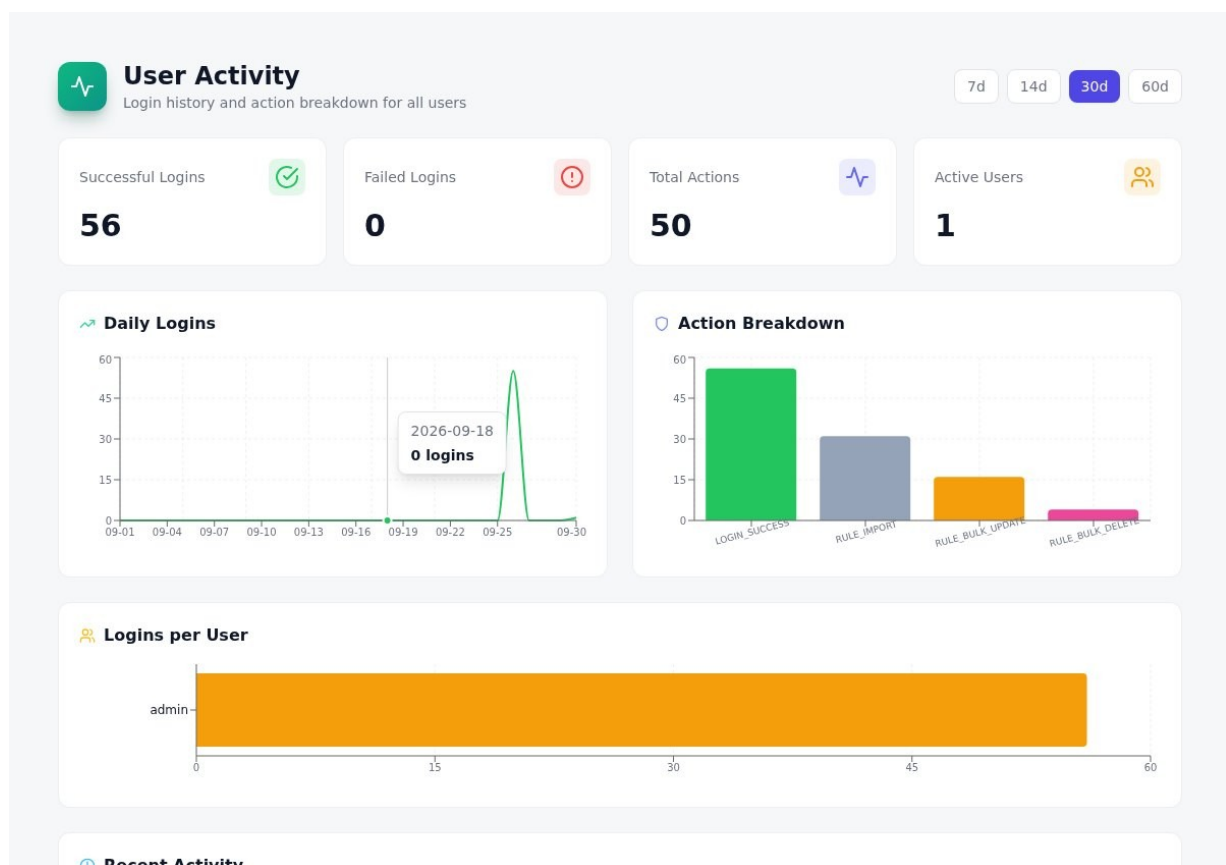
بازگردانی، صفحه‌هایی را که شناسه‌ی آدرس (slug) یکسان دارند بازنویسی می‌کند و قابل بازگشت نیست. قبل از بازگردانی، از وضعیت فعلی پشتیبان بگیرید.

نکته

برای پشتیبان کامل در سطح سرور، دستور `./install.sh update` قبل از هر به‌روزرسانی از دیتابیس MySQL نسخه‌ی پشتیبان می‌گیرد و آن را در پوشه‌ی `backups` ذخیره می‌کند.

گزارش فعالیت (مدیر)

صفحه‌ی **Activity** فعالیت کاربران را در بازه‌ی ۷، ۱۴، ۳۰ یا ۶۰ روز گذشته نشان می‌دهد: تعداد ورودهای موفق و ناموفق، تعداد عملیات، کاربران فعال، نمودار ورود روزانه، تفکیک نوع عملیات (مثل ورود قانون و تغییر گروهی)، ورود هر کاربر و فهرست آخرین رویدادها.



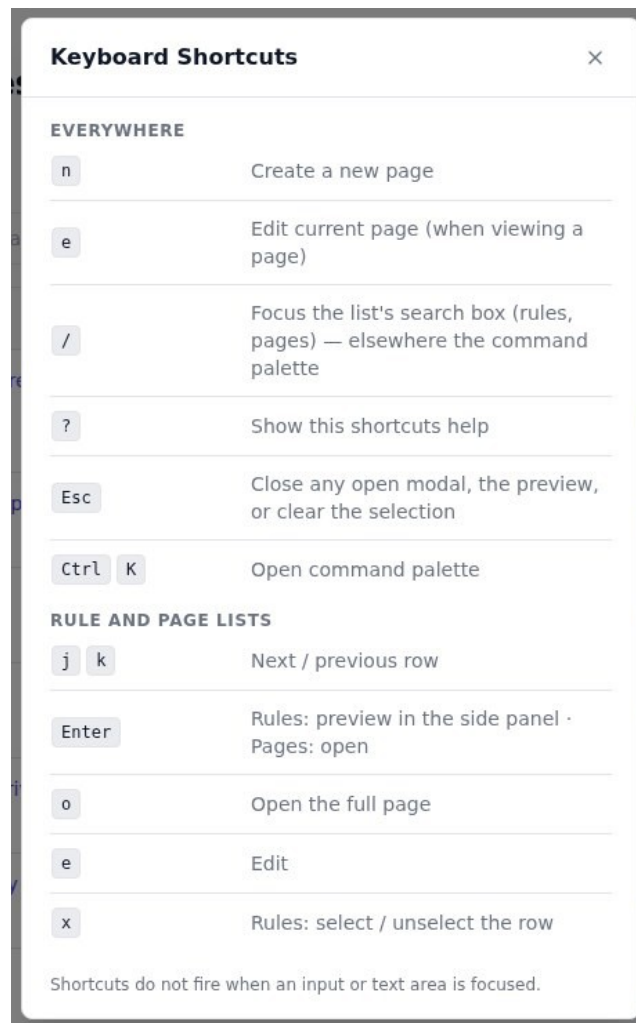
شکل ۴۵ – گزارش فعالیت کاربران

فصل ۱۲ – میانبرهای صفحه‌کلید و ظاهر

با میانبرها، بدون ماوس و سریع‌تر کار می‌کنید. فهرست کامل با کلید **?** در هر صفحه نمایش داده می‌شود.

کلید	کار
Ctrl+K	جست‌وجوی سریع
/	رفتن به جعبه‌ی جست‌وجوی فهرست (قوانین و صفحه‌ها)؛ در صفحه‌های دیگر، جست‌وجوی سریع
n	ساخت صفحه‌ی جدید
e	ویرایش صفحه‌ی فعلی یا ردیف انتخاب‌شده در فهرست
j / k	ردیف بعدی و قبلی در فهرست قوانین و صفحه‌ها. اگر پیش‌نمایش باز باشد، قانون بعدی در آن نمایش داده می‌شود.
Enter	قوانین: باز کردن پیش‌نمایش · صفحه‌ها: باز کردن صفحه
o	باز کردن صفحه‌ی کامل ردیف انتخاب‌شده
x	انتخاب یا لغو انتخاب ردیف (فهرست قوانین)
Esc	بستن پنجره یا پیش‌نمایش؛ بار دوم، پاک کردن انتخاب‌ها
?	نمایش فهرست میانبرها

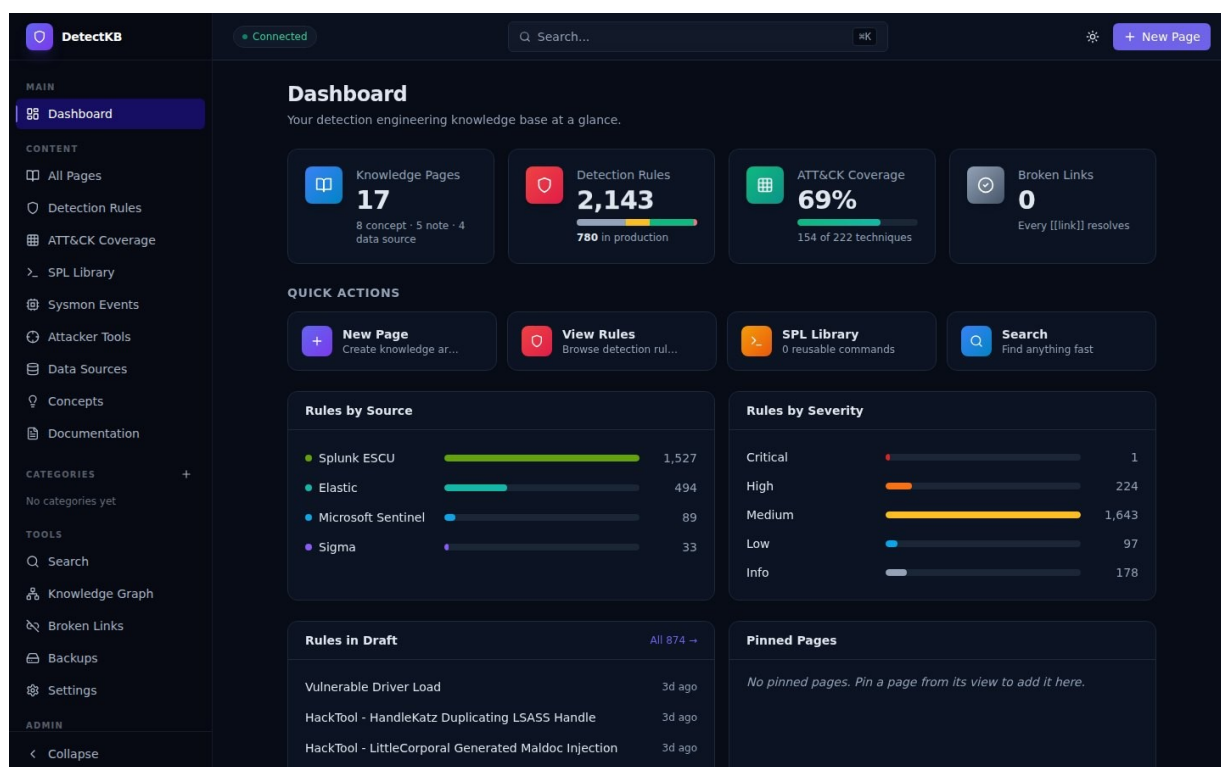
میانبرها وقتی داخل یک جعبه‌ی متن هستید کار نمی‌کنند. برای خروج از جعبه‌ی متن، **Esc** را بزنید یا جای دیگری کلیک کنید.



شکل ۴۶ – پنجره‌ی راهنمای میانبرها

حالت تاریک

با دکمه‌ی ماه یا خورشید در نوار بالا، بین حالت روشن و تاریک جابه‌جا شوید. انتخاب شما در همان مرورگر به خاطر سپرده می‌شود.



شکل ۴۷ - داشبورد در حالت تاریک

فصل ۱۳ – پرسش‌های رایج و عیب‌یابی

چرا قوانینی که وارد کردم در پوشش ATT&CK حساب نشده‌اند؟

پوشش به‌طور پیش‌فرض همه‌ی قوانین به‌جز deprecated را حساب می‌کند. اگر فیلتر وضعیت روی **Production** باشد، قوانین draft حساب نمی‌شوند. همچنین قانون باید در فیلد **MITRE Techniques** شناسه‌ی تکنیک معتبر داشته باشد.

چرا رویداد Sysmon یک قانون تشخیص داده نشده است؟

تشخیص خودکار از کوئری SPL (مثل `EventCode=10` همراه با نام Sysmon) یا logsource قانون Sigma انجام می‌شود. اگر کوئری از ماکرو یا نام دیگری استفاده کند، رویداد را دستی از فرم ویرایش قانون اضافه کنید.

تبدیل Sigma کار نمی‌کند.

اگر پیام **The Sigma conversion service is not running** نمایش داده شود، سرویس تبدیل Sigma اجرا نیست. به مدیر سیستم اطلاع دهید. بقیه‌ی بخش‌های سامانه بدون این سرویس کار می‌کنند.

ابزارهای مهاجم خالی‌اند یا قدیمی شده‌اند.

مدیر باید در صفحه‌ی **Attacker Tools** با **Update from source** داده‌ها را به‌روز کند. روی سرور بدون اینترنت، از **Upload file** استفاده کنید (فصل ۷).

رمزم را فراموش کرده‌ام.

از مدیر سامانه بخواهید با **Reset password** برایتان رمز موقت تعیین کند. بعد از ورود، سامانه از شما می‌خواهد رمز جدید انتخاب کنید.

سامانه بالا نمی‌آید و در لاگ خطای P1000 دیده می‌شود (برای مدیر سیستم).

رمز دیتابیس در فایل `env`. با رمزی که دیتابیس با آن ساخته شده یکی نیست. این معمولاً وقتی پیش می‌آید که فایل `e`. جدیدی کنار دیتابیس قبلی ساخته شود. فایل `env`. نصب قبلی را برگردانید، یا اگر به داده‌ها نیاز ندارید، با `docker compose down -v` دیتابیس را پاک و سامانه را دوباره نصب کنید. جزئیات در بخش Troubleshooting فایل README هست.